

HƯỚNG TỚI PHÁT HIỆN XÂM NHẬP MẠNG THỜI GIAN THỰC BẰNG BIỂU DIỄN ẢNH CỦA CHUỖI GÓI TIN

Jalal Ghadermazi, Ankit Shah (Thành viên Cao cấp IEEE) và Nathaniel D. Bastian (Thành viên Cao cấp IEEE)

Bản dịch tiếng Việt toàn văn từ bài báo đăng trên *IEEE Transactions on Big Data*, Tập 11, Số 1, tháng 1/2 năm 2025, tr. 157-173. Các tên riêng, tên bộ dữ liệu, tên mô hình, ký hiệu toán học và danh mục tài liệu tham khảo được giữ theo nguyên bản để bảo đảm khả năng đối chiếu học thuật.

Tóm tắt

Những tiến bộ của học máy (machine learning - ML) và học sâu (deep learning - DL) đã cải thiện đáng kể khả năng phát hiện bất thường của các hệ thống phát hiện xâm nhập mạng (network intrusion detection systems - NIDS), nhờ cho phép các hệ thống này phân tích Dữ liệu lớn và trích xuất các mẫu. NIDS dựa trên ML/DL được huấn luyện bằng đặc trưng dựa trên luồng hoặc đặc trưng dựa trên gói tin. NIDS dựa trên luồng phù hợp với phân tích lưu lượng ngoại tuyến, trong khi NIDS dựa trên gói tin có thể phân tích lưu lượng và phát hiện tấn công theo thời gian thực. Các phương pháp dựa trên gói tin hiện nay thường phân tích từng gói độc lập, bỏ qua bản chất tuần tự của quá trình truyền thông mạng. Điều này tạo ra các mô hình bị thiên lệch, làm tăng cả âm tính giả lẫn dương tính giả. Ngoài ra, phần lớn NIDS dựa trên gói tin được đề xuất trong tài liệu chỉ thu thập dữ liệu tải (payload), bỏ qua thông tin quan trọng trong phần tiêu đề gói tin. Sự bỏ sót này có thể làm giảm khả năng nhận diện các cuộc tấn công ở mức tiêu đề, chẳng hạn tấn công từ chối dịch vụ.

Để khắc phục các hạn chế trên, chúng tôi đề xuất một khung phương pháp mới có hỗ trợ trí tuệ nhân tạo dành cho NIDS dựa trên gói tin. Khung này phân tích hiệu quả cả dữ liệu tiêu đề lẫn dữ liệu tải, đồng thời xét đến mối liên hệ theo thời gian giữa các gói tin. Khung biến đổi chuỗi gói tin thành ảnh hai chiều, sau đó xây dựng mô hình phát hiện xâm nhập dựa trên mạng nơ-ron tích chập (CNN) để xử lý các ảnh này và phát hiện hoạt động độc hại. Qua các thí nghiệm sử dụng những bộ dữ liệu lớn công khai, chúng tôi chứng minh rằng khung đề xuất đạt tỷ lệ phát hiện cao từ 97,7% đến 99% đối với các loại tấn công khác nhau, đồng thời thể hiện khả năng chống chịu đầy hứa hẹn trước các mẫu đối kháng.

Từ khóa: phát hiện tấn công sớm; hệ thống phát hiện xâm nhập mạng; NIDS dựa trên gói tin; biểu diễn ảnh của chuỗi gói tin.

Thông tin bài báo

Bản thảo được nhận ngày 25/05/2023; sửa đổi ngày 06/02/2024; chấp nhận ngày 08/05/2024. Công bố trực tuyến ngày 20/05/2024; phiên bản hiện tại ngày 16/01/2025. Công trình được hỗ trợ một phần bởi Học viện Quân sự Hoa Kỳ (USMA) theo Thỏa thuận hợp tác, tài trợ số W911NF-22-2-0045, và bởi Trung tâm C5ISR

thuộc Bộ Tư lệnh Phát triển Năng lực Tác chiến Lục quân Hoa Kỳ theo thỏa thuận hỗ trợ số USMA21056. P. D'Urso đề xuất chấp nhận bài báo. Tác giả liên hệ: Ankit Shah.

Jalal Ghadermazi và Ankit Shah công tác tại University of South Florida, Tampa, Florida 33620, Hoa Kỳ. Nathaniel D. Bastian công tác tại United States Military Academy, West Point, New York 10996, Hoa Kỳ. DOI: 10.1109/TBDATA.2024.3403394.

I. GIỚI THIỆU

Hệ thống phát hiện xâm nhập (intrusion detection system - IDS) được thiết kế để giám sát và nhận diện các cuộc tấn công vào hệ thống máy tính và hệ thống mạng của tổ chức. IDS có thể được phân thành hệ thống phát hiện xâm nhập dựa trên máy chủ (host-based IDS - HIDS) và hệ thống phát hiện xâm nhập mạng (network-based IDS - NIDS). NIDS là lựa chọn phổ biến để phát hiện tấn công trong các tổ chức lớn vì chúng phân tích lưu lượng mạng tại các nút quan trọng nhằm nhận diện hành vi tấn công, thay vì chỉ giám sát một nút riêng lẻ như HIDS.

Các chiến lược phát hiện trong NIDS gồm phương pháp dựa trên chữ ký và phương pháp dựa trên bất thường. Trong khi phương pháp dựa trên chữ ký phụ thuộc vào các luật chuyên biệt theo miền, phương pháp dựa trên bất thường sử dụng thuật toán ML/DL và huấn luyện trên Dữ liệu lớn để nhận diện hành vi độc hại. NIDS có hỗ trợ ML/DL chủ yếu được huấn luyện bằng một trong hai loại đặc trưng trích xuất từ dữ liệu lưu lượng mạng: đặc trưng dựa trên luồng và đặc trưng dựa trên gói tin.

Đặc trưng dựa trên luồng tổng hợp thông tin từ tiêu đề gói tin trong các phiên truyền thông mạng, còn đặc trưng dựa trên gói tin được trích xuất trực tiếp từ dữ liệu của từng gói. NIDS dựa trên luồng có nhiều hạn chế. Thứ nhất, chúng chỉ phân tích lưu lượng sau khi luồng giữa bên gửi và bên nhận đã kết thúc để xác định hoạt động độc hại, vì vậy chủ yếu phù hợp với phân tích lưu lượng ngoại tuyến [1]. Thứ hai, chúng chủ yếu trích xuất đặc trưng từ các tầng thấp của mô hình TCP/IP, nên khó phát hiện các cuộc tấn công tầng cao nhằm vào tầng ứng dụng [2]. Ví dụ, một cuộc tấn công từ chối dịch vụ phân tán (DDoS) như SYN flooding nhằm vào dữ liệu tiêu đề gói tin, trong khi tấn công SQL injection chèn mã bất thường vào truy vấn SQL, tức là ở mức dữ liệu tải của gói [3]. Thứ ba, chúng nhận diện tấn công dựa trên các đặc trưng luồng đã trích xuất, vốn không phản ánh đầy đủ hành vi chức năng của lưu lượng mạng thể hiện trong các gói tin. Thứ tư, do có nhiều cách trích xuất đặc trưng luồng khác nhau, chẳng hạn dùng CIC FlowMeter [4] hoặc Zeek (Bro) [5], tập đặc trưng dùng để huấn luyện mô hình phát hiện xâm nhập cũng khác nhau giữa các môi trường mạng. Điều này gây khó khăn khi đánh giá hiệu năng của mô hình đã huấn luyện trong một môi trường đích mới, tức vấn đề khả năng thích nghi miền.

Ngược lại, NIDS dựa trên gói tin phù hợp hơn với phát hiện thời gian thực vì đặc trưng được trích xuất trực tiếp từ dữ liệu gói. Tuy nhiên, cách tiếp cận này cũng có các thách thức. Thứ nhất, việc gán một gói tin là lành tính hay độc hại không hề đơn giản. Không phải mọi gói trong một luồng tấn công đều mang ý đồ độc hại. Chẳng hạn, các gói của thủ tục bắt tay TCP ba bước thể hiện đặc tính mạng bình thường trong cả lưu lượng lành tính lẫn lưu lượng độc hại. Thứ hai, phần lớn NIDS dựa trên gói tin không xét hoạt động tuần tự của các gói trong cùng một luồng mà coi chúng là các gói độc lập. Vì vậy, tương quan theo thời gian giữa các gói thuộc cùng luồng không được nắm bắt [6], có thể dẫn đến phân loại sai. Thứ ba, do giả định độc lập, chúng không xét hướng truyền của gói. Tuy nhiên, hướng của gói trong một luồng - hướng đi hoặc hướng về

- có thể cung cấp thông tin quan trọng để nhận diện tấn công. Ví dụ, các cuộc tấn công như DDoS và quét cổng thường có mẫu gói hướng đi và hướng về khác biệt đáng kể so với lưu lượng bình thường [7].

Nghiên cứu này giải quyết các hạn chế của cả phương pháp dựa trên luồng và phương pháp dựa trên gói tin nhằm phát hiện kịp thời các cuộc tấn công mạng. Chúng tôi đề xuất một phương pháp mới kết hợp ưu điểm của hai cách tiếp cận, bảo toàn mối liên hệ thời gian - không gian giữa các gói và đặc trưng của chúng để nhanh chóng phát hiện nhiều loại tấn công ở cả dữ liệu tiêu đề lẫn dữ liệu tải. Phương pháp trích xuất đặc trưng từ thông tin gói ở tầng cao và tầng thấp, sau đó sử dụng chúng theo thứ tự tuần tự.

Đóng góp chính của nghiên cứu là phát triển một khung phương pháp mới sử dụng kỹ thuật AI để phát hiện tấn công mạng theo thời gian thực hoặc gần thời gian thực. Khung có hỗ trợ AI này khắc phục hạn chế của NIDS dựa trên gói tin truyền thống bằng cách xét đồng thời dữ liệu tiêu đề, dữ liệu tải và các mối liên hệ theo thời gian giữa các gói. Một điểm mới khác là cách biểu diễn dữ liệu lưu lượng mạng. Các gói tuần tự trong một luồng truyền thông được biến đổi thành ảnh hai chiều, cho phép áp dụng CNN để phát hiện xâm nhập. Cách biểu diễn này hỗ trợ xây dựng mô hình NIDS dựa trên CNN đã tối ưu, có khả năng nắm bắt các mẫu và đặc trưng nền liên quan đến tấn công mạng.

Các đóng góp khác gồm những hiểu biết rút ra từ thí nghiệm và phân tích kết quả. Nghiên cứu cho thấy ý đồ độc hại có thể được phát hiện sớm trong quá trình truyền thông của một cuộc tấn công. Chỉ cần quan sát từ gói thứ tư đến gói thứ chín trong phiên truyền thông hai chiều đã đủ để phát hiện hoạt động độc hại với độ chính xác cao. Khả năng phát hiện sớm này tạo ra thay đổi đáng kể trong việc giảm thời gian phản ứng so với phương pháp dựa trên luồng, vốn thường phải chờ phân tích một số lượng lớn gói tin trước khi đưa ra quyết định. Phương pháp còn cho thấy khả năng triển khai trong các môi trường khác nhau mà không cần huấn luyện lại toàn bộ, nhờ đó tăng tính linh hoạt và hiệu quả cho đội ngũ an ninh mạng. Khung SPIN-IDS cũng thể hiện độ vững trước các mẫu đối kháng; nó vẫn phát hiện chính xác tấn công khi gói tin được gây nhiễu có chủ đích, khác với nhiều NIDS dựa trên ML/DL có tỷ lệ âm tính giả cao.

Phần còn lại của bài báo được tổ chức như sau. Phần II tổng quan tài liệu về NIDS dựa trên luồng và NIDS dựa trên gói tin sử dụng ML/DL, đồng thời xác định các khoảng trống nghiên cứu. Phần III mô tả chi tiết phương pháp đề xuất, gồm trích xuất đặc trưng dựa trên gói, biểu diễn ảnh của lưu lượng đang diễn tiến và phát triển mô hình phát hiện xâm nhập mạng. Phần IV trình bày các thí nghiệm số; Phần V trình bày kết quả và phân tích; Phần VI nêu kết luận và các hướng nghiên cứu tương lai.

II. TỔNG QUAN TÀI LIỆU

Trong thập kỷ qua, nhiều nghiên cứu đã tích hợp thuật toán ML/DL vào quá trình phát triển NIDS dựa trên bất thường. NIDS có hỗ trợ ML/DL có thể được xây dựng từ các đặc trưng trích xuất ở mức luồng hoặc từ thông tin lấy trực tiếp ở mức gói. Phần này tóm tắt các nghiên cứu theo hai hướng đó.

A. NIDS dựa trên luồng

Cách tiếp cận phổ biến nhất để xây dựng NIDS là trích xuất đặc trưng dựa trên luồng: phân tích một phiên truyền thông mạng, hay một luồng, rồi tổng hợp thông tin từ các gói của luồng đó. Dữ liệu tiêu đề gói thường

được dùng để tạo đặc trưng luồng [1] bằng các công cụ công khai như CIC FlowMeter [4]. Sau đó, mô hình ML/DL được huấn luyện trên các đặc trưng này để nhận diện bất thường trong lưu lượng mạng.

Mạng nơ-ron sâu (DNN) là một cấu trúc DL cơ bản gồm nhiều lớp đầu vào, lớp ẩn và lớp đầu ra, dùng để mô hình hóa các hàm phi tuyến phức tạp [8], chẳng hạn ánh xạ dữ liệu lưu lượng mạng sang nhãn lành tính hoặc độc hại. Nghiên cứu [9] đề xuất NIDS dùng DNN với bốn lớp ẩn. Thí nghiệm cho thấy mô hình DL này tốt hơn các bộ phân loại ML khác, nhưng độ chính xác phát hiện thấp hơn đối với lớp tấn công user-to-root (U2R). Hiệu năng được đánh giá trên các bộ dữ liệu phát hiện xâm nhập cũ như KDD Cup'99 [10] và NSL-KDD [11].

Mạng nơ-ron hồi quy (RNN), một mở rộng của mạng truyền thẳng truyền thống, cũng được đề xuất để xây dựng NIDS [12]-[14]. Yin và cộng sự [12] trình bày NIDS dựa trên RNN để phân loại nhị phân và đa lớp các mẫu trong NSL-KDD. Hệ thống vượt các bộ phân loại ML nhưng cần tài nguyên tính toán huấn luyện cao hơn, đồng thời có tỷ lệ phát hiện thấp đối với một số loại tấn công như remote-to-local (R2L) và U2R. Xu và cộng sự [13] đề xuất NIDS dựa trên RNN sử dụng gated recurrent unit (GRU). Nghiên cứu dùng các bộ dữ liệu cũ để kiểm chứng và mô hình có độ chính xác thấp hơn trên các lớp tấn công thiếu số. Zavrak và Iskefiyeli [15] giới thiệu SAnDet, một kiến trúc mạng định nghĩa bằng phần mềm để phát hiện bất thường trong lưu lượng. Hệ thống sử dụng replicator neural network và bộ mã hóa - giải mã dựa trên LSTM để nhận diện hiệu quả các cuộc tấn công chưa biết từ đặc trưng luồng lấy ở các bộ chuyển mạch OpenFlow. Naseer và cộng sự [14] so sánh nhiều thuật toán ML/DL và nhận thấy mô hình kết hợp LSTM-CNN đạt độ chính xác tốt hơn; tuy nhiên việc kiểm chứng dựa trên NSL-KDD, một bộ dữ liệu đã cũ và gần như lỗi thời.

Để xử lý tỷ lệ cảnh báo giả cao trong NIDS dựa trên ML/DL, các tác giả [16] xây dựng phương pháp không giám sát pVoxel nhằm nhận diện dương tính giả mà không cần biết trước về cảnh báo. Bằng cách gom các điểm thành voxel và phân tích đặc trưng mật độ, pVoxel giảm 95,55% dương tính giả trên 11 phương pháp phát hiện lưu lượng tiên tiến khi thí nghiệm với 75 bộ dữ liệu thực tế. Chai và cộng sự [17] định nghĩa lại bài toán phát hiện mã độc chưa biết thành bài toán học ít mẫu và đề xuất mạng nguyên mẫu động dựa trên thích nghi mẫu (DPNSA). DPNSA tích hợp tích chập động để trích xuất đặc trưng thích nghi, định nghĩa đặc trưng lớp là trung bình của các embedding động và sử dụng hàm kích hoạt động hai mẫu để tăng hiệu quả phát hiện mã độc thông qua tính khoảng cách dựa trên metric.

Autoencoder (AE) là kỹ thuật DL sử dụng học không giám sát, trong đó các mẫu đầu vào không có nhãn [18]. Shone và cộng sự [19] đề xuất NIDS kết hợp AE sâu và Random Forest, cho hiệu quả tốt hơn phương pháp deep belief network trong [20]. Yan và cộng sự [21] sử dụng stacked sparse autoencoder (SSAE) và SVM. Yang và cộng sự [22] đề xuất mô hình SAVAER-DNN, kết hợp variational autoencoder có giám sát, regularization và DNN, hiệu quả đối với các cuộc tấn công tần suất thấp và tấn công mới. Tuy nhiên, các mô hình dựa trên AE này đều được đánh giá trên KDD Cup'99 và NSL-KDD, đồng thời cho độ chính xác thấp hơn ở các lớp tấn công thiếu số. Nghiên cứu [23] tập trung phát hiện lưu lượng mạng bất thường hoặc xâm nhập từ dữ liệu luồng bằng các phương pháp học sâu không giám sát trong thiết lập bán giám sát; cụ thể, AE và VAE được dùng để nhận diện tấn công chưa biết từ đặc trưng luồng.

CNN thường được dùng cho phân loại ảnh và phát hiện đối tượng vì có khả năng nắm bắt thông tin không gian bằng các bộ lọc tích chập. Đặc trưng luồng không có quan hệ không gian, nên CNN thường xuất hiện trong hệ lai với RNN: CNN làm bộ trích xuất đặc trưng, sau đó RNN thực hiện phân loại [24]-[26]. Yu và cộng sự [27] đề xuất NIDS dựa trên học ít mẫu, sử dụng DNN và CNN làm hàm embedding để trích xuất đặc trưng và giảm chiều. Các mô hình này được đánh giá trên KDD Cup'99, NSL-KDD và UNSW-NB15, nhưng độ chính xác phát hiện thấp hơn đối với các lớp tấn công thiếu số.

B. NIDS dựa trên gói tin

Một phương pháp khác để xây dựng NIDS có hỗ trợ ML/DL là trích xuất đặc trưng trực tiếp từ từng gói trong một luồng, sau đó huấn luyện mô hình trên các đặc trưng gói. Phương pháp RNN có cơ chế attention ATPAD trong [28] sử dụng word embedding và RNN để trích xuất những đặc trưng phản ánh tương quan giữa kết quả phát hiện và các byte tiềm ẩn trong payload. Phương pháp thực hiện phân loại nhị phân và được huấn luyện trên CIC-IDS2017 [29]. Nghiên cứu [3] cũng dùng bộ dữ liệu này để tạo chuỗi khối từ dữ liệu payload của gói, qua đó nắm bắt quan hệ phụ thuộc ngắn hạn và dài hạn giữa các byte độc hại. Công cụ payload-byte trong [30] được đề xuất để trích xuất các byte payload từ những bộ dữ liệu công khai chứa tệp pcap. Từ các gói đã trích xuất, mô hình DNN được huấn luyện để phát hiện các loại tấn công. Kết quả cho thấy NIDS dựa trên gói tin có thể hiệu quả tương đương NIDS dựa trên luồng.

Tuy nhiên, các nghiên cứu [3], [28], [30] chỉ thu thập đặc trưng payload, trong khi tính độc hại của một số cuộc tấn công nằm ở dữ liệu tiêu đề [2]. Các nghiên cứu này cũng chỉ xét những gói có payload và chưa xây dựng cấu trúc để thu thập tuần tự các gói thuộc cùng luồng, nên khó nhận diện tấn công theo thời gian thực.

Các tác giả [31] đề xuất một biểu diễn gói thống nhất dùng thông tin gói thô để nhận dạng hệ điều hành và thiết bị của máy chủ. Phương pháp được thử nghiệm trên mười bộ dữ liệu. Dù phù hợp cho fingerprint hệ điều hành, nó không thích hợp để phân loại lưu lượng mạng. Phương pháp đưa toàn bộ byte của gói thô vào mô hình, kể cả tiêu đề chứa địa chỉ IP và cổng. Cách bao quát này có thể khiến mô hình học ghi nhớ các địa chỉ IP thường tạo lưu lượng độc hại hoặc các cổng thường bị tấn công.

Zhang và cộng sự [32] đề xuất tạo ảnh xám từ gói tin mà không thực hiện trích xuất đặc trưng. Mỗi gói được giả định có 1518 byte payload hệ thập lục phân và được đệm 0. Sơ đồ mã hóa p-zigzag tạo ảnh xám, sau đó ảnh được biến đổi bằng biến đổi cosin rời rạc nghịch đảo để tạo ảnh kết cấu mẫu phục vụ phân loại. Tuy nhiên, quan hệ thời gian - không gian giữa các gói trong cùng luồng bị bỏ qua vì mỗi ảnh chỉ biểu diễn một gói. Tương tự [31], phương pháp bao gồm mọi trường nên quá trình huấn luyện có thể thiên lệch theo địa chỉ IP hoặc cổng.

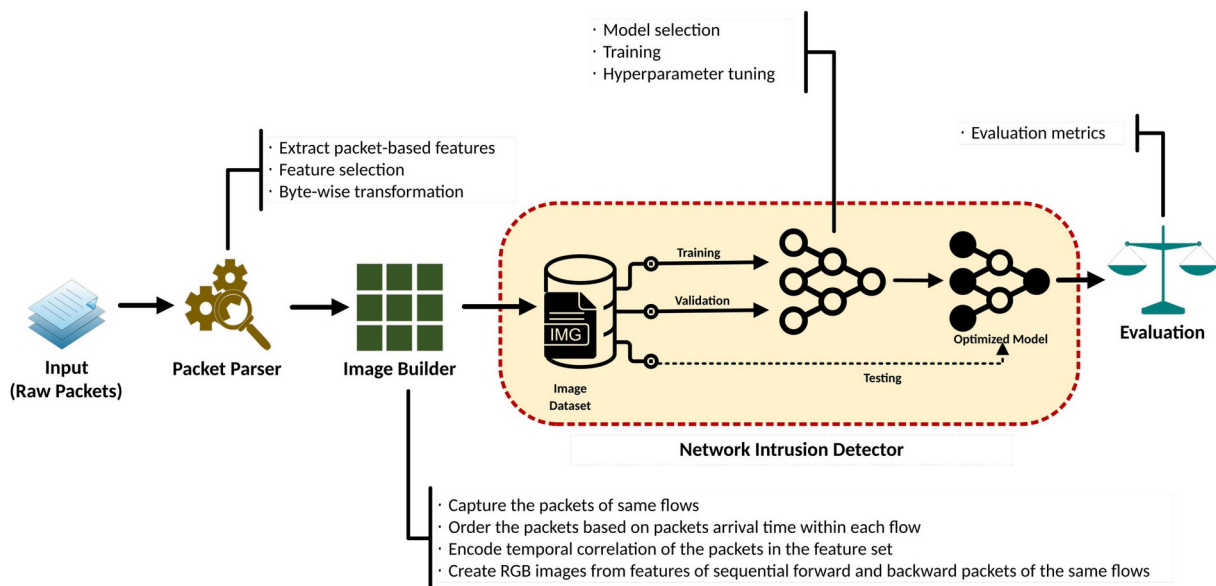
Yu và cộng sự [33] đề xuất PBCNN, một IDS dựa trên CNN. Phương pháp thu thập dữ liệu gói thô và tạo một ảnh duy nhất gồm tất cả các gói thuộc một luồng hoặc phiên. PBCNN có hiệu quả cao trên các bộ dữ liệu hiện đại như CIC-IDS2017 và CIC-IDS2018. Tuy nhiên, phương pháp không phù hợp cho phát hiện thời gian thực vì phải thu đủ một số gói cố định trong phiên/luồng - 20 gói - trước khi dự đoán, tương tự phương pháp dựa trên luồng. Dùng số gói cố định để tạo ảnh còn có thể bỏ sót các luồng chỉ gồm rất ít gói, chẳng hạn một số luồng DDoS. Ngoài ra, ảnh xám không phản ánh cách các gói hướng đi và hướng về được truyền, nên không nắm bắt được mẫu của các gói hướng đi do kẻ tấn công gửi. Việc giữ các trường đặc thù theo mạng như cổng nguồn, cổng đích và giao thức cũng làm mô hình thiên lệch theo những thông tin này.

C. Khoảng trống nghiên cứu

Tóm lại, NIDS dựa trên gói tin rất phù hợp để phát hiện tấn công theo thời gian thực hoặc gần thời gian thực vì phản ánh trạng thái hiện tại của mạng và có thể phát hiện bất thường ngay khi chúng xuất hiện. Tuy nhiên, các phương pháp hiện tại thường dựa trên hai giả định mạnh. Thứ nhất, mọi gói thuộc một luồng tấn công đều bị gán là độc hại khi huấn luyện, trong khi rõ ràng không phải mọi gói trong toàn bộ phiên truyền thông

tổ chức cuộc tấn công đều mang tính độc hại. Thứ hai, mỗi gói được đánh giá độc lập mà không xét sự phụ thuộc với các gói khác trong cùng luồng.

Trong triển khai thực tế, giả định này dẫn đến dương tính giả vì mô hình sẽ phân loại nhiều gói vô hại là độc hại, tạo lượng cảnh báo lớn mà chuyên viên an ninh phải điều tra trong điều kiện nguồn lực hạn chế. Đồng thời, phương pháp cũng có thể bỏ sót tấn công, gây âm tính giả. Việc truy ngược một gói riêng lẻ về đúng luồng để điều tra còn làm quy trình phát hiện và giảm thiểu xâm nhập phức tạp hơn, đòi hỏi thêm thời gian xử lý. Ngoài ra, phần lớn NIDS dựa trên gói tin chỉ lấy payload, bỏ qua lượng thông tin đáng kể trong tiêu đề. Một số nghiên cứu [31], [32] đã xét cả tiêu đề và payload, nhưng đưa toàn bộ dữ liệu tiêu đề vào có thể tạo thiên lệch trong huấn luyện và làm giảm độ chính xác khi triển khai mô hình ở môi trường mạng khác.



Hình 1. Khung hệ thống phát hiện xâm nhập mạng dựa trên ảnh của chuỗi gói tin (SPIN-IDS).

III. KHUNG PHƯƠNG PHÁP CÓ HỖ TRỢ AI

Mục tiêu của nghiên cứu là khắc phục các khoảng trống nêu trên bằng cách xây dựng một cơ chế phát hiện xâm nhập nhanh và chính xác, có thể nhận diện một cuộc tấn công mạng với độ tin cậy cao từ số lượng gói tối thiểu trong một luồng đang diễn tiến. Khung có hỗ trợ AI được minh họa trong Hình 1 thực hiện mục tiêu này bằng cách xét đồng thời dữ liệu tiêu đề và payload của các gói tuần tự trong một luồng đang phát triển, rồi biến đổi chúng thành biểu diễn ảnh hai chiều (2D).

Khung hệ thống phát hiện xâm nhập mạng dựa trên ảnh của chuỗi gói tin (sequential packets image-based network intrusion detection system - SPIN-IDS) gồm ba thành phần: (i) bộ phân tích gói tin, (ii) bộ tạo ảnh và (iii) bộ phát hiện xâm nhập mạng. Thành phần thứ nhất trích xuất đặc trưng ở mức gói từ dữ liệu lưu lượng thô. Thành phần thứ hai tiền xử lý dữ liệu đặc trưng để tạo ảnh 2D. Thành phần thứ ba xác định lưu lượng là lành tính hay độc hại.

A. Bộ phân tích gói tin

Để hiểu cách trích xuất đặc trưng ở mức gói từ tệp gói thô, cần nắm được cấu trúc lưu trữ của gói tin. Mô hình TCP/IP là mô hình chuẩn điều phối việc trao đổi thông tin qua Internet. Mô hình gồm bốn tầng: tầng truy cập mạng, còn gọi là tầng host-to-network; tầng Internet; tầng vận chuyển; và tầng ứng dụng. TCP chịu trách nhiệm chia thông điệp thành các segment TCP và tái lắp ghép chúng tại đích. Hình 2 thể hiện các tầng TCP/IP cùng số byte thông tin ở mỗi tầng. Dữ liệu lưu lượng mạng thường được lưu theo định dạng libpcap (pcap), tiêu chuẩn thực tế cho việc bắt gói mạng và được dùng rộng rãi trong các công cụ bắt, phân tích gói như Wireshark [34].

Bộ phân tích gói tin nhận đầu vào là lưu lượng mạng thời gian thực hoặc các tệp pcap. Mỗi gói truyền qua TCP có thể chứa tối đa 1594 byte thông tin. Các thông tin phụ thuộc môi trường và giao thức có thể làm mô hình thiên lệch và giảm khả năng áp dụng ở môi trường khác. Vì vậy, để loại bỏ thiên lệch, phương pháp bỏ các trường sau: tiêu đề Ethernet dài 14 byte; phiên bản IP một byte; trường differentiated services một byte; trường protocol một byte; địa chỉ IP nguồn và đích, mỗi địa chỉ bốn byte; cổng nguồn và cổng đích trong tiêu đề TCP, mỗi cổng hai byte. IP options và TCP options cũng bị loại bỏ vì có thể làm các byte giữa hai gói cùng luồng bị lệch vị trí và đưa nhiều vào mô hình. Hiện tượng lệch vị trí xuất hiện khi biểu diễn đặc trưng của gói có options và gói không có options không thẳng hàng, làm giảm hiệu năng và khả năng diễn giải của mô hình [31].

Để mã hóa quan hệ thời gian giữa các gói trong cùng luồng, phương pháp bổ sung đặc trưng delta time, tính chênh lệch thời gian giữa hai gói cùng luồng từ epoch time của từng gói. Sau khi loại bỏ tổng cộng 109 byte thông tin, được đánh dấu màu đỏ trong Hình 2, và mã hóa đặc trưng tương quan thời gian vào không gian đặc trưng, biểu diễn đặc trưng gói thu được, ký hiệu V_{packet} , chứa tối đa 1486 byte thông tin. Mỗi byte tương ứng với một đặc trưng. Sau đó, phép biến đổi theo từng byte chuyển giá trị hệ thập lục phân sang giá trị thập phân tương ứng, từ 0 đối với 00B đến 255 đối với ff. Miền giá trị này phù hợp với biểu diễn ảnh. Do số byte thay đổi theo loại gói, không gian đặc trưng được đệm 0 để duy trì cấu trúc chuẩn, tạo ra số đặc trưng cố định N cho mỗi gói.

Một số cuộc tấn công cố giữ máy chủ đích bận và tiêu thụ tài nguyên bằng cách gửi nhiều gói rỗng không chứa dữ liệu độc hại rõ ràng, chẳng hạn SYN flooding [35]. Vì vậy, cần phân biệt gói hướng đi từ kẻ tấn công đến máy chủ và gói hướng về từ máy chủ đến kẻ tấn công. Hướng của mỗi gói được mã hóa thành một đặc trưng phụ trợ. Tổng cộng, bảy đặc trưng phụ trợ được thu từ mỗi gói: địa chỉ IP nguồn (SrcIP), địa chỉ IP đích (DstIP), cổng nguồn (SrcPort), cổng đích (DstPort), giao thức (Proto), epoch time và hướng gói. Bảy đặc trưng này chỉ đóng vai trò hỗ trợ trong bộ tạo ảnh, không thuộc tập đặc trưng gói dùng để huấn luyện.

Kích thước cuối cùng của vector đặc trưng gói là 1486 và chỉ các đặc trưng này được dùng để tạo ảnh. Hình 3 minh họa lược đồ dữ liệu. Đầu ra của bộ phân tích gói gồm bảy đặc trưng phụ trợ và 1486 đặc trưng dựa trên gói. Ban đầu, hướng và delta time được đặt là null; hai giá trị này được tính trong bộ tạo ảnh.

Network Access layer	ETH header = 14 bytes	
	18 66 da 9b e3 7d 00 19 b9 0a 69 f1 08 00	
Internet layer	IP header = 20 bytes	IP options = maximum 40 bytes
	45 00 01 c7 c5 00 40 00 40 06 de aa c0 a8 0a 32 c0 a8 0a 03	00 00 00 00 00 ... 00 00 00 00 00
Transport layer	TCP header = 20 bytes	TCP options = maximum 40 bytes
	db 2c 0c c4 6a 70 fd 5c 36 30 df a9 80 18 01 79 d0 aa 00 00	01 01 08 0a ... cc 4a 38 80 68 25
Application layer	Segment data (payload) = maximum 1460 bytes	
	00 00 01 8f 60 82 01 8b 06 09 2a 86 48 02 02 01 11 ... 01 90 83 53 37 c3 3e 2b 6b 3a f6 89 88 8a	

Hình 2. Các tầng của mô hình TCP/IP và chi tiết số byte thông tin.

Thuật toán 1. Quy trình của bộ phân tích gói tin

Đầu vào: dữ liệu mạng thời gian thực hoặc dữ liệu mạng đã bắt trong tệp pcap.

Đầu ra: dữ liệu gói đã biến đổi.

1. Đặt độ dài tập đặc trưng gói là N cho mọi gói.
2. Với mỗi gói:
 - Lấy dữ liệu tiêu đề và payload.
 - Chọn các đặc trưng từ dữ liệu tiêu đề và payload.
 - Biến đổi từng byte từ hệ thập lục phân sang giá trị thập phân 0-255.
 - Gán dữ liệu đã biến đổi vào vector đặc trưng V_packet .
 - Thêm đặc trưng delta time vào V_packet và ban đầu đặt là null.
 - Nếu độ dài V_packet khác N thì đệm 0.
 - Thu thập và bổ sung các đặc trưng phụ trợ vào V_packet .

B. Bộ tạo ảnh

Để nắm bắt quan hệ thời gian - không gian giữa các gói trong một luồng, nghiên cứu xây dựng bộ tạo ảnh 2D kích thước $P \times Q$, sử dụng chuỗi gói để tạo các ảnh chụp trạng thái của luồng khi từng gói mới đến. Dữ liệu gói đã biến đổi từ bộ phân tích là đầu vào của bộ tạo ảnh. Nhờ các đặc trưng phụ trợ, những gói thuộc cùng luồng được gom lại, sau đó tính delta time và hướng truyền.

Delta time được mã hóa như một đặc trưng; các gói cùng luồng được xếp chồng theo chiều P của ảnh để giữ quan hệ thời gian. Tương quan không gian và ngữ nghĩa trong gói được bảo toàn bằng biểu diễn tĩnh của đặc trưng gói theo chiều Q . Giá trị P có thể do đội ngũ an ninh của tổ chức lựa chọn, chẳng hạn dựa trên trung bình hoặc trung vị số gói trong mỗi luồng của môi trường mạng đó. Giá trị Q bằng độ dài vector đặc trưng gói, tức 1486. Việc tạo ảnh không đòi hỏi phải chờ đủ P gói của luồng.

Các đặc trưng gói được lưu trong ảnh ba kênh đỏ (R), xanh lá (G) và xanh dương (B). Ảnh RGB được lựa chọn vì trạng thái của các gói hướng đi và hướng về rất quan trọng để nhận diện mẫu tấn công. Ảnh xám sẽ làm mất mẫu này. Kênh R lưu thông tin gói hướng đi, kênh G lưu thông tin gói hướng về. Vì truyền thông chỉ có hai hướng, kênh B không mang thêm thông tin và được đệm 0 để mọi ảnh có cùng cấu trúc.

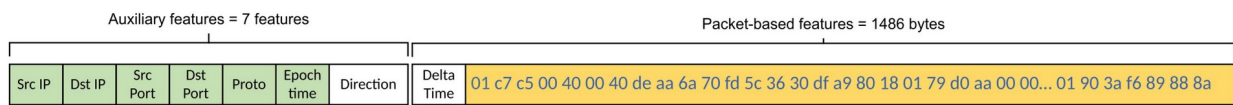
Việc lưu gói hướng đi trong kênh R còn có thể giảm tác động của các nhiễu nhỏ do kẻ tấn công đưa vào dữ liệu gói nhằm né NIDS. Với biểu diễn ảnh của chuỗi gói, những nhiễu nhỏ hoặc thay đổi nhẹ thường không đủ làm biến đổi các mẫu có thể phân biệt trong ảnh. Quá trình được thực hiện tuần tự: mỗi khi một gói đến, hệ thống kiểm tra hướng và gán vector đặc trưng vào kênh tương ứng, hai kênh còn lại để trống.

Việc tạo ảnh từ luồng có ba ý nghĩa chính. Thứ nhất, nó nắm bắt quan hệ thời gian - không gian bằng delta time và bằng cách xếp chồng gói cùng luồng theo chiều ảnh. Thứ hai, hướng truyền của gói được dùng để

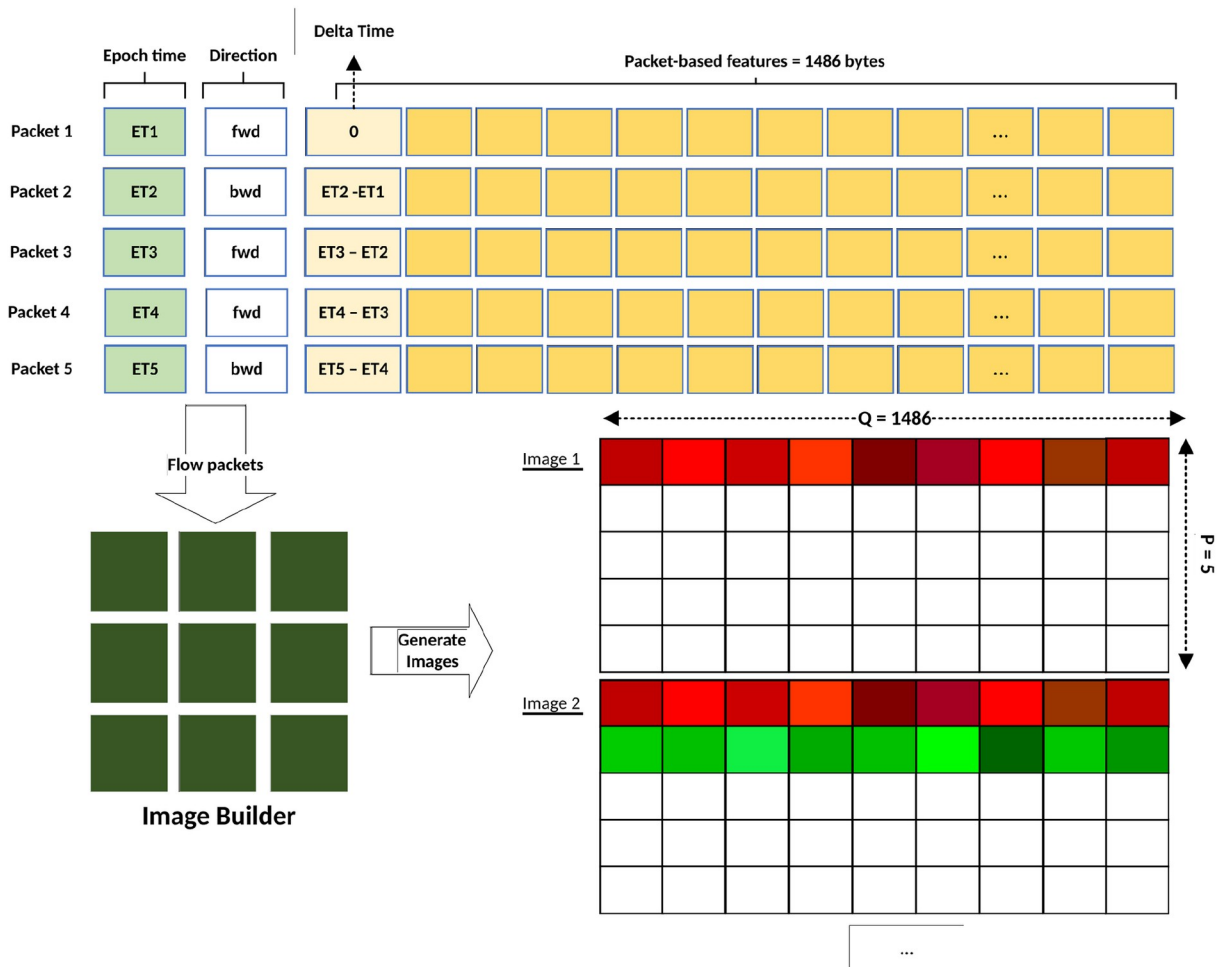
nhận diện tấn công thông qua hai kênh R và G. Thứ ba, cách biểu diễn này tăng độ vững của mô hình trước các thay đổi nhỏ do kẻ tấn công tạo ra, vì mẫu tổng thể trong ảnh vẫn được duy trì.

Để huấn luyện bộ phát hiện xâm nhập, có thể dùng dữ liệu lịch sử của tổ chức hoặc các bộ dữ liệu xâm nhập hiện đại, phổ biến do Canadian Institute for Cybersecurity cung cấp, chẳng hạn CIC-IDS2017 [29] và CIC-IDS2018 [4]. Mỗi ảnh tạo trong pha huấn luyện được gán nhãn của luồng trong dữ liệu lịch sử hoặc bộ dữ liệu công khai. Ví dụ, ảnh từ CIC-IDS2017 thuộc một trong 15 nhãn, gồm một nhãn lành tính và 14 loại tấn công.

Hình 4 minh họa một luồng đang diễn tiến có năm gói. Gói đầu đi theo hướng forward nên vector đặc trưng được lưu ở kênh R của hàng đầu tiên, còn G và B được đệm 0. Gói thứ hai đi theo hướng backward nên vector đặc trưng được lưu ở kênh G của hàng thứ hai, còn R và B được đệm 0. Quá trình tiếp tục đến khi cả năm gói được biểu diễn.



Hình 3. Biểu diễn các đặc trưng phụ trợ và đặc trưng dựa trên gói tin.



Hình 4. Sơ đồ quá trình tạo ảnh, minh họa việc tạo hai ảnh đầu tiên của một luồng.

Thuật toán 2. Quy trình của bộ tạo ảnh

Đầu vào: dữ liệu gói từ Thuật toán 1 và tham số P.

Đầu ra: dữ liệu ảnh.

1. Với mỗi gói trong dữ liệu gói:
 - Tìm các gói có cùng bộ năm giá trị (SrcIP, DstIP, SrcPort, DstPort, Proto) và gán nhãn là gói hướng đi.
 - Tìm các gói có bộ năm giá trị đảo chiều (DstIP, SrcIP, DstPort, SrcPort, Proto) và gán nhãn là gói hướng về.
 - Sắp xếp các gói của luồng theo epoch time.
2. Với mỗi gói trong luồng:
 - Tính delta time bằng epoch time của gói hiện tại trừ epoch time của gói trước.
 - Biến đổi delta time về khoảng [0, 255].
 - Mã hóa delta time vào vector đặc trưng V_packet.
3. Đặt kích thước ảnh là P x 1486 x 3 và đệm 0 các kênh R, G, B.
4. Đặt p = 0 để đánh số hàng ảnh theo trình tự.
5. Với mỗi gói trong luồng:
 - Nếu p >= P thì dừng.
 - Nếu hướng gói là forward, gán vector đặc trưng của gói vào hàng p của kênh R.
 - Nếu hướng gói là backward, gán vector đặc trưng của gói vào hàng p của kênh G.
 - Tạo ảnh gồm p gói trong luồng.
 - Tăng p lên 1.
6. Loại các gói của luồng vừa xử lý khỏi dữ liệu gói.
7. Trả về dữ liệu ảnh.

C. Bộ phát hiện xâm nhập mạng

Mục tiêu của bộ phát hiện là xác định một ảnh từ bộ tạo ảnh chứa lưu lượng lành tính hay độc hại. Bài toán phát hiện xâm nhập được mô hình hóa thành phân loại ảnh nhị phân: xác định bản chất của hoạt động mạng đang diễn tiến và gán nó vào một trong hai lớp benign hoặc malicious. Nghiên cứu sử dụng kiến trúc CNN vì CNN có hiệu năng cao trong phân loại ảnh và thời gian suy luận nhanh [36].

CNN có kiến trúc nhiều lớp khác với mạng truyền thẳng thông thường. Mạng gồm lớp đầu vào, lớp đầu ra và nhiều lớp ẩn, thường gồm các lớp tích chập, lớp gộp như max-pooling và lớp kết nối đầy đủ. Hai thao tác cốt lõi là tích chập và lấy mẫu [37]. Trong tích chập, nhiều bộ lọc được áp dụng lên dữ liệu gốc hoặc feature map rồi cộng thêm bias. Kích thước đầu ra của một chiều ảnh sau lớp tích chập được xác định bởi:

$$L' = (L - K + 2Z) / S + 1 \quad (1)$$

trong đó L là chiều dài đầu vào, K là kích thước kernel, Z là số phần tử đệm 0 ở hai đầu chiều ảnh và S là stride của kernel.

Dùng nhiều lớp tích chập có thể giúp học tốt hơn các ảnh có đặc trưng phức tạp, nhưng số lớp và hiệu năng không phải lúc nào cũng tỷ lệ thuận. Vì vậy, trong pha huấn luyện cần lựa chọn kiến trúc phù hợp từ nhiều khả năng, từ mạng nông chỉ có một lớp tích chập đến mạng sâu có nhiều lớp, đồng thời thử các chiến lược padding và stride khác nhau. Hàm mất mát, hàm kích hoạt và các siêu tham số cũng phải phù hợp với bài toán phân loại nhị phân.

Trong huấn luyện, từ mỗi luồng tạo nhiều ảnh với số gói tuần tự tăng dần. Mục tiêu thí nghiệm là xác định số gói thích hợp để bộ phát hiện học được mẫu truyền thông và đạt độ chính xác cao hơn khi phát hiện lưu lượng độc hại.

Thuật toán 3. Huấn luyện và xác thực bộ phát hiện xâm nhập mạng

Đầu vào: dữ liệu ảnh huấn luyện, dữ liệu ảnh xác thực, tập siêu tham số và kiến trúc CNN.

Đầu ra: mô hình đã tối ưu.

1. Trong khi quá trình huấn luyện chưa hoàn tất:
 - Với mỗi cấu hình siêu tham số:
 - Với mỗi epoch:
 - Tạo các batch ảnh từ dữ liệu huấn luyện và xác thực.
 - Huấn luyện CNN bằng các batch ảnh huấn luyện.
 - Đánh giá mô hình trên dữ liệu xác thực.
 - Nếu early stopping được kích hoạt thì dừng, nếu không thì tiếp tục.
 - Lưu cấu hình siêu tham số và hiệu năng xác thực.
2. Chọn cấu hình siêu tham số tốt nhất.
3. Trả về mô hình đã tối ưu.

1) Đánh giá

Hiệu năng của bộ phát hiện được đánh giá bằng các chỉ số thường dùng trong phát hiện xâm nhập. Các giá trị dự đoán gồm:

- **Dương tính thật (TP):** số mẫu tấn công được phân loại đúng là tấn công.
- **Âm tính giả (FN):** số mẫu tấn công bị phân loại sai thành lưu lượng lành tính.
- **Dương tính giả (FP):** số mẫu lành tính bị phân loại sai thành tấn công.
- **Âm tính thật (TN):** số mẫu lành tính được phân loại đúng.

Các chỉ số được tính như sau:

- **Độ chính xác:** $\text{Accuracy} = (\text{TP} + \text{TN}) / (\text{TP} + \text{TN} + \text{FP} + \text{FN})$. (2)
- **Precision:** $\text{Precision} = \text{TP} / (\text{TP} + \text{FP})$. (3)
- **Tỷ lệ dương tính thật hoặc Recall/Detection Rate:** $\text{TPR} = \text{TP} / (\text{TP} + \text{FN})$. (4)

- **F1-score:** $F1 = 2 \times (\text{Precision} \times \text{Recall}) / (\text{Precision} + \text{Recall})$. (5)
- **Tỷ lệ âm tính thật:** $TNR = TN / (TN + FP)$. (6)
- **Tỷ lệ âm tính giả:** $FNR = FN / (TP + FN)$. (7)
- **Tỷ lệ dương tính giả, còn gọi là false alarm rate:** $FPR = FP / (FP + TN)$. (8)

IV. THÍ NGHIỆM SỐ

Phần này trình bày tổng quan các thí nghiệm số dùng để đánh giá phương pháp. Trước hết, nghiên cứu mô tả dữ liệu lưu lượng mạng; tiếp theo là quá trình tạo biểu diễn ảnh; sau đó trình bày cách chia dữ liệu thành tập huấn luyện, xác thực và kiểm thử để phát triển bộ phát hiện xâm nhập. Thí nghiệm được thực hiện trên bộ xử lý Intel Core i9-12950HX thế hệ 12, bộ nhớ đệm 30 MB, 24 luồng và 16 lõi. Để tăng tốc huấn luyện, nghiên cứu sử dụng GPU NVIDIA RTX A5500 với 16 GB GDDR6 SDRAM, cùng phiên bản CUDA mới nhất và thư viện tăng tốc mạng nơ-ron sâu cuDNN.

A. Mô tả dữ liệu

Các thí nghiệm sử dụng tập pcap thô từ hai bộ dữ liệu phát hiện xâm nhập nổi tiếng: CIC-IDS2017 [29] và CIC-IDS2018 [4]. Hai bộ dữ liệu chứa cả truyền thông lành tính lẫn truyền thông tấn công và thể hiện lưu lượng mạng hiện đại thực tế hơn các bộ dữ liệu cũ như NSL-KDD và KDD-CUP [38]. Tập pcap của CIC-IDS2017 chứa lưu lượng trong năm ngày liên tiếp từ thứ Hai đến thứ Sáu; mỗi ngày có loại và quy mô tấn công khác nhau, như Bảng I. Nghiên cứu dùng các thư viện Python dpkt [39] và Scapy [40] để phân tích lưu lượng thô và tạo tập đặc trưng gói theo quy trình ở Phần III. Bảng II cho biết số gói hướng đi và hướng về được trích xuất cho từng loại tấn công. Đầu ra của bộ phân tích gói được kiểm chứng bằng phiên bản đã sửa của các tập NetFlow CSV công khai dành cho CIC-IDS2017 [41].

Bảng I. Chi tiết các tập pcap của CIC-IDS2017

Ngày	Kích thước tập	Hoạt động
Thứ Hai, 03/07/2017	11 GB	Lành tính
Thứ Ba, 04/07/2017	11 GB	Brute Force và lành tính
Thứ Tư, 05/07/2017	13 GB	DoS và lành tính
Thứ Năm, 06/07/2017	7,7 GB	Web Attack, Infiltration và lành tính
Thứ Sáu, 07/07/2017	8,2 GB	Botnet, Port Scan, DDoS và lành tính

Bảng II. Số gói theo từng loại tấn công trong CIC-IDS2017

Loại tấn công	Gói hướng đi	Gói hướng về
DoS GoldenEye	66.795	39.382
DoS Hulk	1.246.802	1.000.016
DoS Slowhttptest	32.635	7.027
DoS Slowloris	37.236	10.350
DDoS	754.735	510.922
Heartbleed	28.412	20.884
SSH Patator	65.695	97.616
FTP Patator	43.507	67.229

Botnet	4.788	5.083
Infiltration	29.881	29.873
Port Scan	162.630	160.677
Web Attack-Brute force	19.755	10.304
Web Attack-XSS	6.361	3.277
Web Attack-SQL Injection	67	59

Để đánh giá khả năng chuyển mô hình sang dữ liệu lưu lượng khác, tức khả năng thích nghi miền, nghiên cứu sử dụng CIC-IDS2018. Bộ dữ liệu này chứa nhiều loại tấn công và nhiều tệp pcap có kích thước khác nhau như Bảng III. Để chứng minh khả năng thích nghi của SPIN-IDS với mô hình đã huấn luyện, nghiên cứu trích xuất gói cho các nhóm DoS, Web Attack, Infiltration và Brute Force. Số gói hướng đi và hướng về được trình bày trong Bảng IV.

Bảng III. Chi tiết các tệp pcap của CIC-IDS2018

Ngày	Kích thước tệp	Hoạt động
Thứ Tư, 14/02/2018	40 GB	SSH và FTP Patator; lành tính
Thứ Năm, 15/02/2018	41,3 GB	DoS GoldenEye, DoS Slowloris; lành tính
Thứ Sáu, 16/02/2018	38,6 GB	DoS Slowhttptest, DoS Hulk; lành tính
Thứ Năm, 22/02/2018	50,3 GB	Web Attack và lành tính
Thứ Sáu, 23/02/2018	60 GB	Web Attack và lành tính
Thứ Tư, 28/02/2018	53,3 GB	Infiltration và lành tính

Bảng IV. Số gói theo từng loại tấn công trong CIC-IDS2018

Loại tấn công	Gói hướng đi	Gói hướng về
DoS GoldenEye	154.774	98.976
DoS Hulk	10.286.619	107.067
Infiltration	236.560	86.054
FTP Patator	193.360	193.360
Web Attack-Brute force	20.735	14.158
Web Attack-XSS	22.289	11.586

B. Tạo dữ liệu ảnh

Sau khi trích xuất đặc trưng gói từ CIC-IDS2017 và CIC-IDS2018, bộ tạo ảnh được dùng để tạo các tập ảnh theo quy trình ở Phần III. CIC-IDS2017 được dùng để phát triển bộ phát hiện, còn CIC-IDS2018 đại diện cho môi trường mạng khác và được dùng để đánh giá khả năng chuyển giao của mô hình đã huấn luyện.

Mục tiêu là phát hiện tính độc hại càng sớm càng tốt. Tham số P xác định chiều cao ảnh, tức số gói tuần tự tối đa của một luồng có thể xuất hiện trong mẫu ảnh. P phải đủ lớn để nắm bắt mẫu phức tạp của nhiều loại

tấn công, nhưng cũng phải đủ nhỏ để ảnh có kích thước gọn và được xử lý hiệu quả. Để chọn P, nghiên cứu xem xét thống kê số gói theo từng loại tấn công trong CIC-IDS2017, trình bày ở Bảng V.

Cột “Số luồng” trong Bảng V cho biết tổng số luồng trích xuất của lớp lành tính và các lớp tấn công. Do số gói trong mỗi luồng thay đổi, nghiên cứu tính trung bình, trung vị và mode. Ví dụ, luồng lành tính có trung bình 85,76 gói, nhưng mode bằng 14, nghĩa là luồng 14 gói xuất hiện thường xuyên nhất. Các giá trị đều tính cả gói hướng đi và hướng về.

Có thể thấy giá trị trung bình khá cao ở mọi lớp, trong khi trung vị và mode thấp hơn. Điều này cho thấy phân phối lệch phải, trong đó một số ít giá trị rất lớn kéo trung bình lên. Vì vậy, chọn trung vị làm chiều cao tối đa của ảnh sẽ vừa giữ đủ gói để phản ánh ý đồ của phiên truyền thông, vừa tạo ảnh nhỏ hơn nhiều so với dùng trung bình. Nghiên cứu chọn trung bình đã làm tròn của các giá trị trung vị, bằng 15, làm P và đặt kích thước ảnh là 15 x 1486 x 3.

Bảng V. Thống kê luồng theo loại tấn công trong CIC-IDS2017

Loại tấn công	Nhãn	Số luồng	Số gói TB	Trung vị	Mode
Benign	0	103.138	85,76	15	14
DoS Slowloris	1	1.554	30,62	10	7
DoS Slowhttptest	2	1.586	25,07	13	2
DoS Hulk	3	128.566	17,47	14	14
DoS GoldenEye	4	6.704	15,83	14	14
Heartbleed	5	1.656	29,76	21	6
FTP-Patator	6	475	233,13	6	4
SSH-Patator	7	457	357,35	6	4
Web Attack-Brute Force	8	222	135,45	17	2
Web Attack-XSS	9	69	139,68	3	2
Web Attack-SQL Injection	10	2	63	63	63
Infiltration	11	4.254	14,04	6	2
Botnet	12	736	13,41	9	9
PortScan	13	7.674	42,13	22	6
DDoS	14	167.232	7,56	2	2
Trung bình		28.288,33	80,68	14,73	10,06

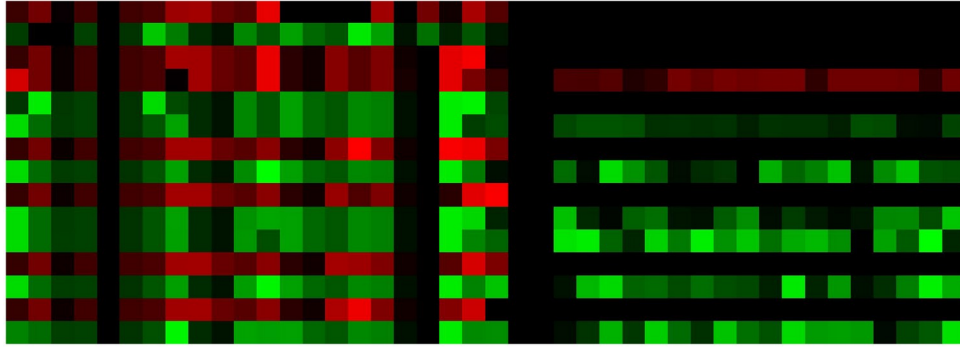
Với mỗi luồng, nghiên cứu tạo nhiều ảnh, từ ảnh chỉ có một gói đến ảnh có P gói tuần tự; do đó mỗi luồng có thể sinh tối đa P ảnh. Bảng VI trình bày tập ảnh đầu ra; “pkt” là viết tắt của “packet”. Mỗi cột biểu diễn tập ảnh có số gói cố định được lấy từ các luồng thuộc một hoạt động mạng cụ thể: một lớp lành tính và 14 loại tấn công. Chẳng hạn, cột 15 pkts gồm 61.159 ảnh lành tính nhãn 0 và 15.636 ảnh DDoS nhãn 14, cùng các ảnh của những lớp còn lại. Tất cả ảnh trong cột này chứa 15 gói tuần tự đầu tiên của luồng tương ứng.

Bảng VI. Số mẫu ảnh được tạo theo số lượng gói khác nhau

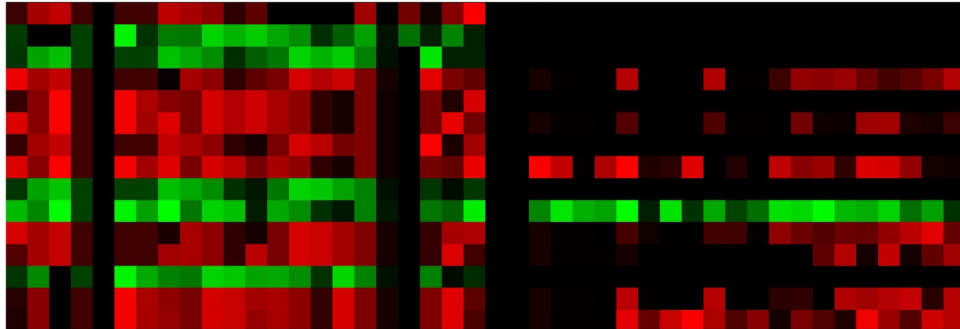
Nhãn	1 pkt	2 pkts	3 pkts	4 pkts	5 pkts	6 pkts	...	11 pkts	12 pkts	13 pkts	14 pkts	15 pkts
0	103138	102889	102688	101637	101547	101320	...	92548	89580	83490	74974	61159

Bản dịch tiếng Việt - SPIN-IDS

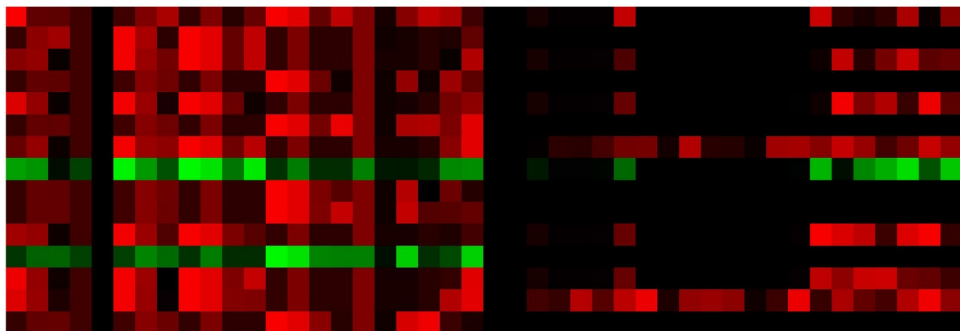
1	1554	1529	1522	1342	1331	1269	...	769	721	651	606	585
2	1586	1581	1296	1109	1093	1074	...	883	830	796	774	737
3	128566	128339	128207	127508	127457	127297	...	120492	116460	102844	83426	53841
4	6704	6607	6580	6539	6484	6312	...	5852	5645	4864	3849	2301
5	1656	1656	1652	1650	1642	1632	...	1334	1304	1271	1245	1211
6	475	464	461	437	275	260	...	121	106	96	93	89
7	457	457	454	420	265	254	...	142	135	126	120	115
8	222	221	166	160	147	144	...	135	133	131	130	127
9	69	66	41	27	21	19	...	17	16	16	15	15
10	2	2	2	2	2	2	...	2	2	2	2	2
11	4254	3798	3334	2921	2550	2253	...	1203	1057	933	834	743
12	736	736	736	736	736	736	...	116	45	45	44	44
13	7674	7671	7506	7386	7306	7284	...	5953	5813	5730	5633	5466
14	167232	167118	33812	33507	33073	32996	...	30490	28721	25573	20575	15636



(a) Benign



(b) DDoS



(c) Heartbleed

Hình 5. Một số mẫu ảnh do bộ tạo ảnh sinh ra từ 15 gói tuần tự: (a) lành tính, (b) DDoS, (c) Heartbleed.

Tiếp theo, dữ liệu được chia thành ba tập riêng cho huấn luyện, xác thực và kiểm thử. Quá trình chia dữ liệu tuân theo các nguyên tắc sau:

- Loại Web Attack-XSS, Web Attack-SQL Injection và Botnet khỏi huấn luyện vì số ảnh của các lớp này quá ít, như các hàng được tô sáng trong Bảng VI.
- Lấy cùng số lượng ảnh ở mỗi dạng biểu diễn từ 1 pkt đến 14 pkts như số lượng có trong tập 15 pkts, nhằm tránh mô hình thiên lệch về một dạng biểu diễn.
- Bảo đảm các dạng ảnh khác nhau của cùng một luồng không xuất hiện chéo giữa huấn luyện, xác thực và kiểm thử; mỗi tập chứa đủ P dạng biểu diễn nhưng từ các luồng khác nhau.
- Cân bằng dữ liệu huấn luyện bằng cách lấy số ảnh gần bằng nhau cho từng loại tấn công, sao cho tổng ảnh độc hại của tất cả loại tấn công bằng tổng ảnh lành tính. Cụ thể, lấy 100 ảnh cùng luồng ở mỗi loại tấn công và mỗi trong 15 dạng biểu diễn, riêng FTP-Patator lấy 89 ảnh.

Sau khi áp dụng các điều kiện trên, dữ liệu được chia theo tỷ lệ 70% huấn luyện, 15% xác thực và 15% kiểm thử.

C. Phát triển mô hình phát hiện xâm nhập mạng

Nghiên cứu thử nhiều kiến trúc CNN, từ mạng nông một lớp tích chập đến mạng sâu bảy lớp tích chập, cùng các chiến lược padding và stride khác nhau. Các chiến lược pooling cực đại và pooling trung bình cũng được đánh giá. Kiến trúc tối ưu được minh họa trong Hình 6.

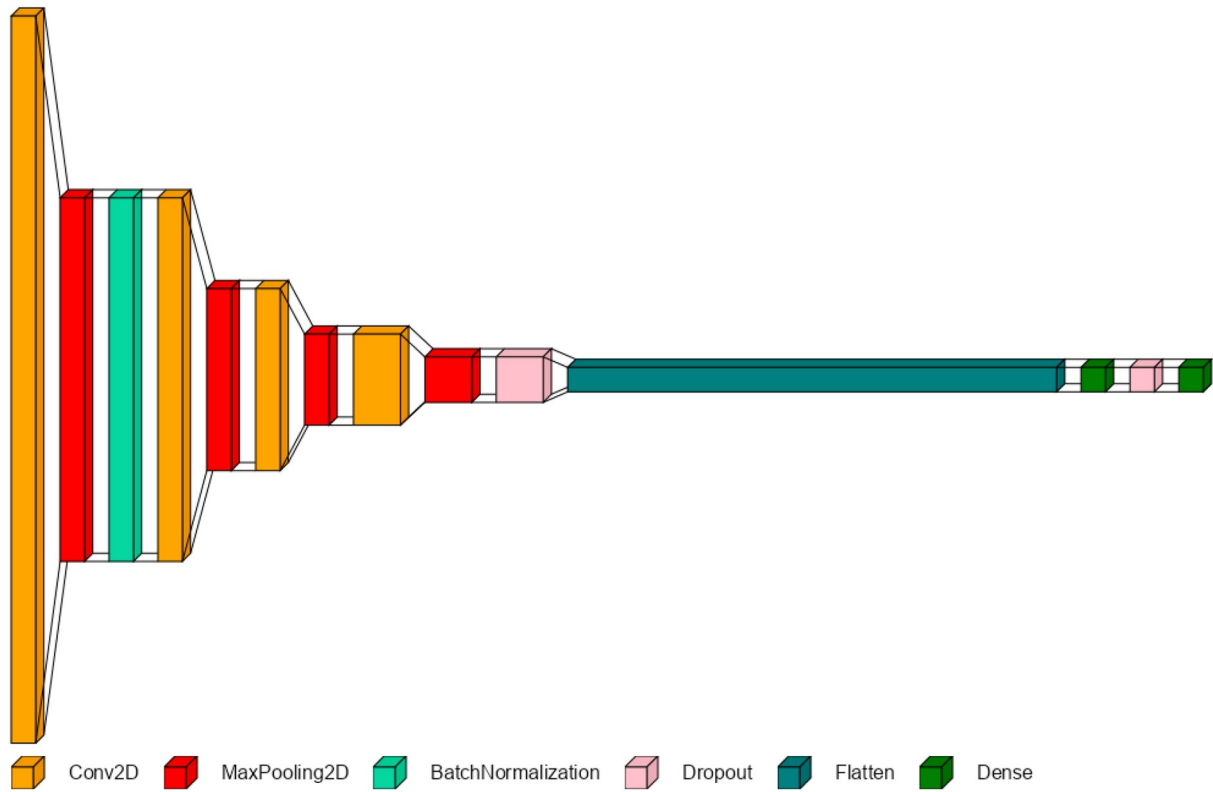
Các lớp tích chập dùng same padding để đầu ra có cùng kích thước không gian với đầu vào; stride mặc định $S = (1, 1)$. Một lớp batch normalization được đặt sau lớp pooling đầu tiên để tăng tốc học và cải thiện độ ổn định. Hai lớp dropout với tỷ lệ 20% được dùng để hạn chế overfitting.

Do đây là phân loại nhị phân, mô hình dùng Binary Crossentropy làm hàm mất mát và Sigmoid ở lớp dense cuối để tạo đầu ra trong khoảng $[0,1]$. Các siêu tham số quan trọng được tối ưu bằng tập huấn luyện và xác thực. Mô hình được cài đặt bằng TensorFlow [42], dùng KerasTuner [43] và TensorBoard để tối ưu siêu tham số. Bảng VII liệt kê không gian giá trị và giá trị tốt nhất. Mỗi thử nghiệm được huấn luyện tối đa 100 epoch. Đường cong học của cấu hình tốt nhất được trình bày trong Hình 7. Mô hình tối ưu sau đó được đánh giá trên tập kiểm thử trong nhiều kịch bản.

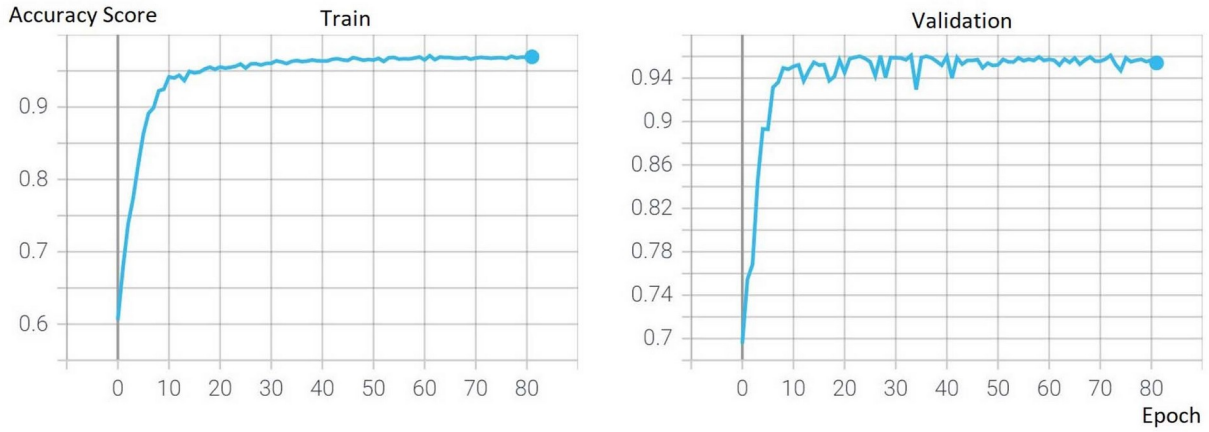
Bảng VII. Giá trị siêu tham số của mô hình phát hiện xâm nhập dựa trên CNN

Siêu tham số	Các giá trị thử	Giá trị tốt nhất
Hàm kích hoạt	[ReLU, tanh, LeakyReLU]	ReLU
Khởi tạo kernel	[GlorotNormal, HeNormal, HeUniform, RandomUniform]	GlorotNormal
Số filter lớp tích chập 1	16-128, bước 16	96
Kernel lớp tích chập 1	(3,3), (4,4), (5,5)	(5,5)
Số filter lớp tích chập 2	32-256, bước 32	128
Kernel lớp tích chập 2	(3,3), (4,4), (5,5)	(5,5)

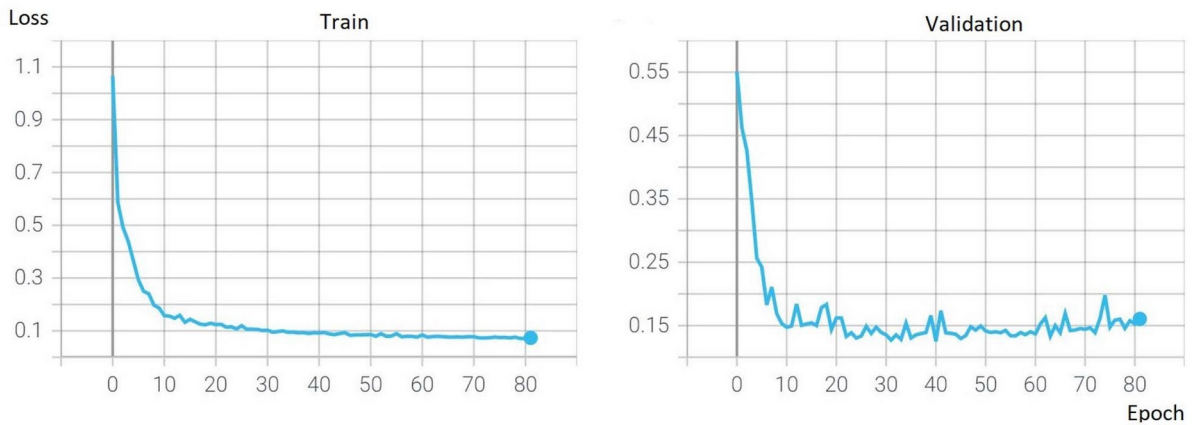
Số filter lớp tích chập 3	32-512, bước 32	192
Kernel lớp tích chập 3	(3,3), (4,4), (5,5)	(3,3)
Số filter lớp tích chập 4	32-512, bước 32	384
Kernel lớp tích chập 4	(3,3), (4,4), (5,5)	(4,4)
Số unit lớp dense 1	16-128, bước 16	64
Kích thước batch	[64, 128, 256, 512]	256
Learning rate	[1e-2, 1e-3, 1e-4]	0,001
Optimizer	[SGD, RMSprop, Adam]	RMSprop



Hình 6. Kiến trúc CNN của bộ phát hiện xâm nhập mạng.



(a) Accuracy



(b) Loss

Hình 7. Đường cong học của mô hình đã tối ưu.

V. KẾT QUẢ VÀ PHÂN TÍCH

Phần này trình bày kết quả thí nghiệm với khung SPIN-IDS. Trước hết, nghiên cứu đánh giá hiệu quả trên tập kiểm thử CIC-IDS2017, phân tích hiệu năng theo số gói trong ảnh và thời điểm thông tin độc hại xuất hiện. Tiếp theo là khả năng phát hiện từng loại tấn công và phân tích thống kê độ lệch khỏi hành vi lành tính. Nghiên cứu còn đánh giá độ vững trước mẫu đối kháng, khả năng thích nghi sang môi trường CIC-IDS2018 và so sánh với các phương pháp dựa trên gói tin gần đây.

A. Hiệu năng theo các dạng biểu diễn ảnh

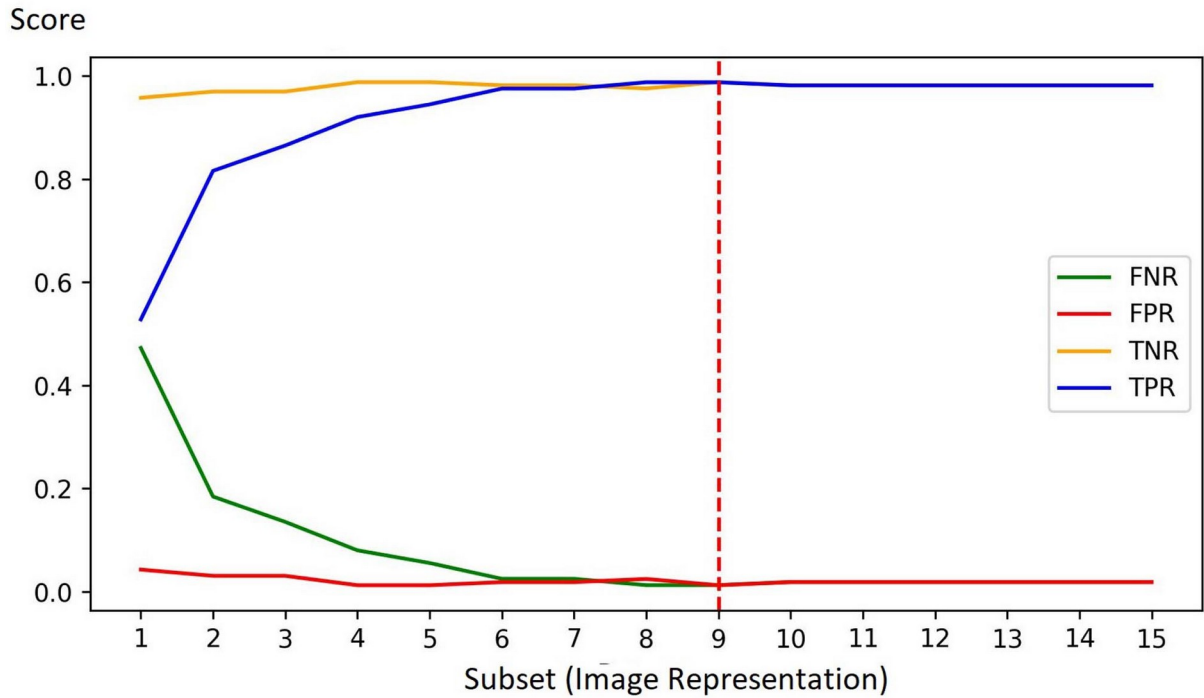
Tập kiểm thử gồm 15 dạng ảnh của cùng các luồng: từ ảnh chứa gói đầu tiên đến ảnh chứa 15 gói tuần tự đầu tiên. Mỗi dạng được xem là một tập con. Tập con 1 chứa ảnh từ gói đầu tiên; tập con 2 chứa ảnh từ hai gói đầu; các tập tiếp theo lần lượt tăng đến 15 gói. Trong mỗi tập con, số mẫu của các loại tấn công được lấy gần bằng nhau và gộp thành lớp độc hại; lớp lành tính cũng có số mẫu gần bằng lớp độc hại. Mỗi tập con gồm 328 ảnh: 165 lành tính và 163 độc hại.

Bảng VIII cho thấy hiệu năng tăng khi số gói trong ảnh tăng. Kết quả tốt nhất trên hầu hết chỉ số xuất hiện với ảnh chín gói tuần tự, đạt TPR 98,77%. Hình 8 minh họa xu hướng cải thiện. Hiệu năng gần như bão hòa sau chín gói, cho thấy tính độc hại có thể được nhận diện với độ chính xác cao trong chín gói đầu của luồng đang diễn tiến.

Mô hình không thể nhận diện chính xác mẫu độc hại khi ảnh chỉ chứa gói đầu tiên, với TPR 52,76%. Điều này cho thấy gói đầu của phiên có thể chưa mang ý đồ độc hại và các gói độc hại xuất hiện sau. Đáng chú ý, chỉ sau bốn gói, TPR đã đạt 92,02%. Kết quả phù hợp với việc ba gói đầu thường thuộc bắt tay TCP ba bước để thiết lập kết nối tin cậy. Phương pháp có thể phát hiện hoạt động độc hại trong chín gói đầu, trong khi phương pháp dựa trên luồng phải chờ trung bình khoảng 80 gói, theo Bảng V.

Bảng VIII. Hiệu năng mô hình trên các dạng ảnh của tập kiểm thử CIC-IDS2017

Tập con	Accuracy	Precision	F1	TNR	FNR	TPR/Recall	FPR/FAR
1	0,7439	0,9247	0,6719	0,9576	0,4724	0,5276	0,0424
2	0,8933	0,9638	0,8837	0,9697	0,1840	0,8160	0,0303
3	0,9177	0,9658	0,9126	0,9697	0,1350	0,8650	0,0303
4	0,9543	0,9868	0,9524	0,9879	0,0798	0,9202	0,0121
5	0,9665	0,9872	0,9655	0,9879	0,0552	0,9448	0,0121
6	0,9787	0,9815	0,9785	0,9818	0,0245	0,9755	0,0182
7	0,9787	0,9815	0,9785	0,9818	0,0245	0,9755	0,0182
8	0,9817	0,9758	0,9817	0,9758	0,0123	0,9877	0,0242
9	0,9878	0,9877	0,9877	0,9879	0,0123	0,9877	0,0121
10	0,9817	0,9816	0,9816	0,9818	0,0184	0,9816	0,0182
11	0,9817	0,9816	0,9816	0,9818	0,0184	0,9816	0,0182
12	0,9817	0,9816	0,9816	0,9818	0,0184	0,9816	0,0182
13	0,9817	0,9816	0,9816	0,9818	0,0184	0,9816	0,0182
14	0,9817	0,9816	0,9816	0,9818	0,0184	0,9816	0,0182
15	0,9817	0,9816	0,9816	0,9818	0,0184	0,9816	0,0182



Hình 8. Hiệu năng mô hình theo các dạng biểu diễn ảnh.

B. Hiệu năng phát hiện từng loại tấn công

Trong thí nghiệm này, nghiên cứu dùng toàn bộ ảnh chín gói còn lại của từng loại tấn công, không dùng trong huấn luyện, xác thực hoặc kiểm thử trước đó. Bảng IX cho biết các chỉ số cho từng loại. Recall trung bình trên mọi loại tấn công vượt 98,5%, cho thấy mô hình nhận diện tốt các mẫu độc hại nền. Mô hình đạt độ chính xác 100% với SSH-Patator và FTP-Patator. Nhìn chung, SPIN-IDS kết hợp CNN và ảnh chín gói hoạt động rất tốt trên mọi loại tấn công, đồng thời giữ FN và FP ở mức thấp.

Bảng IX. Phân tích phát hiện theo từng loại tấn công

Tấn công	Số mẫu	Accuracy	Precision	F1	TNR	FNR	TPR	FPR
DoS Slowloris	1728	0,9838	0,9860	0,9838	0,9861	0,0185	0,9815	0,0139
DoS Slowhttptest	1680	0,9875	0,9858	0,9875	0,9857	0,0107	0,9893	0,0143
DoS Hulk	164735	0,9787	0,9936	0,9855	0,9819	0,0223	0,9777	0,0181
DoS GoldenEye	11864	0,9729	0,9612	0,9733	0,9602	0,0143	0,9857	0,0398
Heartbleed	2670	0,9843	0,9850	0,9843	0,9850	0,0165	0,9835	0,0150
FTP-Patator	150	1	1	1	1	0	1	0
SSH-Patator	134	1	1	1	1	0	1	0
Web Attack-Brute Force	78	0,9872	0,9750	0,9873	0,9744	0	1	0,0256
Infiltration	2854	0,9926	0,9951	0,9926	0,9951	0,0098	0,9902	0,0049
PortScan	124192	0,9789	0,9796	0,9789	0,9797	0,0218	0,9782	0,0203
DDoS	64512	0,9854	0,9812	0,9851	0,9820	0,0110	0,9890	0,0180

Tiếp theo, nghiên cứu phân tích thống kê thời điểm luồng độc hại bắt đầu lệch khỏi hành vi lành tính. Với mỗi loại tấn công và mỗi dạng ảnh từ một đến 15 gói, một ảnh đại diện được tạo bằng cách lấy trung bình giá

trị pixel của toàn bộ ảnh trong nhóm đó. Một ảnh đại diện tương ứng cũng được tạo cho lưu lượng lành tính. Hai ảnh được so sánh bằng tỷ số tín hiệu trên nhiễu cực đại (peak signal-to-noise ratio - PSNR) [46]:

$$\text{PSNR} = 10 \log_{10} \left\{ (2^d - 1)^2 \frac{P \cdot Q}{\sum_{i=1}^P \sum_{j=1}^Q (p[i,j] - p'[i,j])^2} \right\} \quad (9)$$

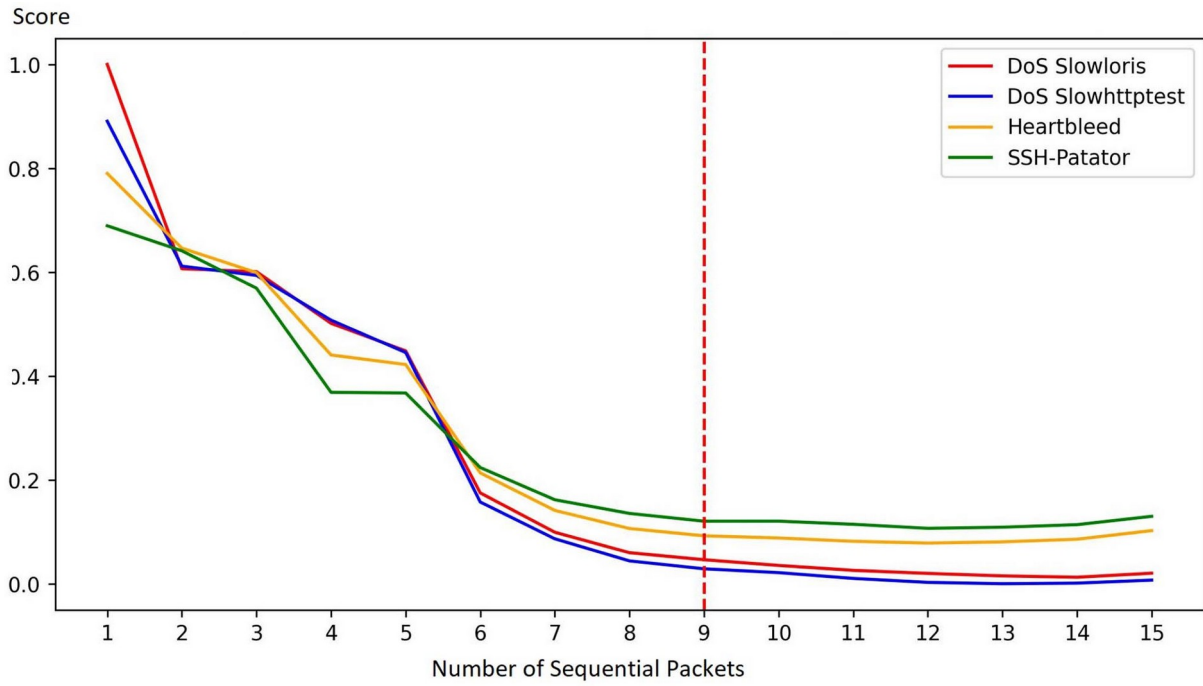
Trong đó d là số kênh ảnh; Q và P lần lượt là chiều rộng và chiều cao; $p[i,j]$ và $p'[i,j]$ là giá trị pixel ở hàng i , cột j của ảnh đại diện lành tính và độc hại. PSNR đo bằng decibel và không có miền cố định. Giá trị càng cao cho thấy ảnh tấn công càng giống ảnh lành tính. Nghiên cứu diễn giải như sau:

- PSNR cao, chẳng hạn trên 30 dB: ảnh tấn công rất giống ảnh lành tính.
- PSNR trung bình khoảng 20-30 dB: có mức tương đồng vừa phải và chỉ một số khác biệt nhỏ.
- PSNR thấp dưới 20 dB: có khác biệt đáng kể giữa ảnh tấn công và ảnh lành tính.

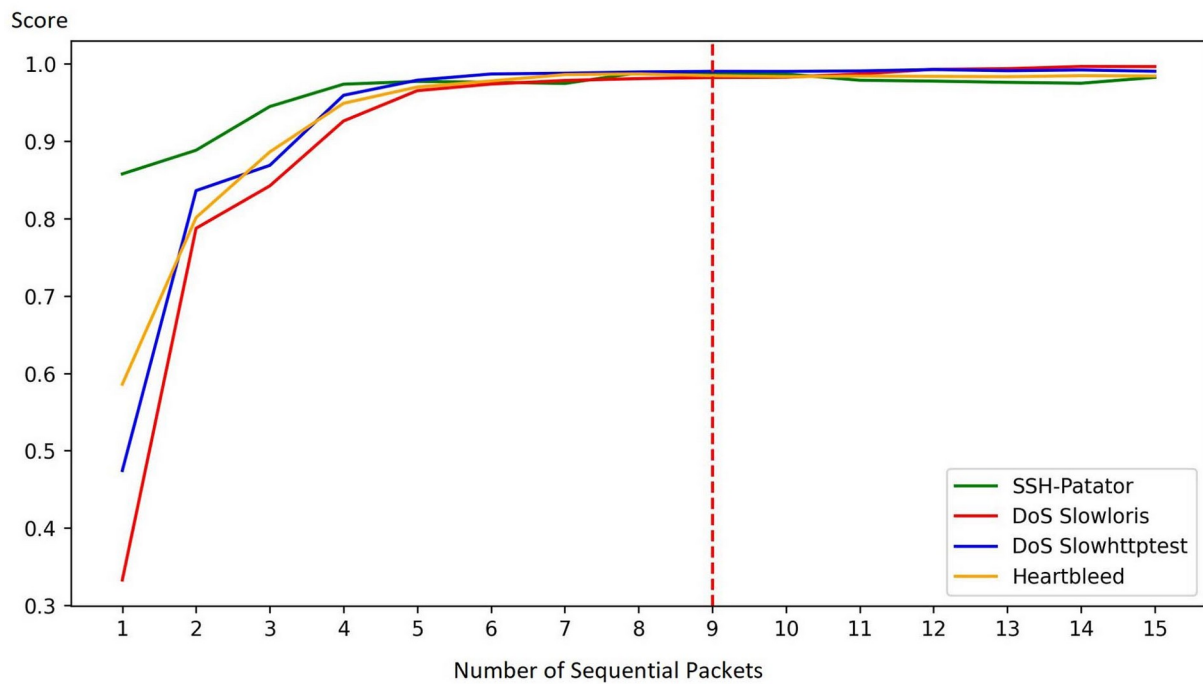
Phân tích được thực hiện trên cả 15 dạng ảnh cho từng loại tấn công. Bài báo trình bày bốn loại đại diện: SSH-Patator, DoS Slowloris, DoS Slowhttptest và Infiltration. Hình 9 biểu diễn PSNR đã chuẩn hóa theo phần trăm; PSNR thực tế nằm trong khoảng 23,76-53,70 dB. Với ảnh một đến sáu gói, PSNR của mọi loại đều trên 30 dB, nghĩa là khác biệt rất nhỏ và khó nhận biết bằng quan sát thủ công. Sau sáu gói, PSNR vẫn trên 20 dB nhưng khác biệt đã rõ hơn. Hình 10 trình bày recall của bốn loại theo từng số gói. Các loại khác cũng có xu hướng tương tự.

Đồ thị recall và PSNR cho thấy tương quan mạnh giữa các gói cụ thể và hiệu năng mô hình. Ví dụ, với DoS Slowloris, ảnh một gói có recall thấp nhất, 33,3%, và PSNR cho thấy ảnh đại diện rất giống lớp lành tính. Khi thêm gói thứ hai, recall tăng mạnh lên 78,7%, mức tăng lớn nhất, đồng thời PSNR giảm mạnh xuống 60,6% theo thang chuẩn hóa, mức giảm lớn nhất. Các loại tấn công khác cũng thể hiện hiện tượng tương tự.

Dù ba gói đầu thường thuộc bắt tay TCP, một số byte trong tiêu đề vẫn truyền thông tin quan trọng giúp nhận diện tính độc hại, chẳng hạn time-to-live (TTL), cờ IP, urgent pointer và window size. Vì phương pháp thu cả tiêu đề và payload, bộ phát hiện vẫn nhận diện được độ lệch khỏi truyền thông lành tính trong những mẫu này. PSNR và recall cùng bão hòa sau khoảng chín gói, cho thấy các gói mang ý đồ độc hại đã xuất hiện trong phần truyền đầu tiên của luồng.



Hình 9. Điểm PSNR của các dạng ảnh theo loại tấn công so với lưu lượng lành tính.



Hình 10. Recall của các dạng ảnh theo loại tấn công.

C. Hiệu năng trước các mẫu đối kháng

Mẫu đối kháng được tạo để né cơ chế phát hiện của NIDS. Kẻ tấn công có thể chỉnh sửa nhẹ lưu lượng hợp lệ hoặc tạo lưu lượng độc hại được thiết kế cẩn thận nhằm đánh lừa thuật toán ML/DL. Các thay đổi như sửa byte, làm lệch thời điểm hoặc thứ tự gói có thể khai thác điểm yếu của NIDS, dẫn đến âm tính giả và cho phép xâm nhập không bị phát hiện.

Để đánh giá độ vững, nghiên cứu tạo các mẫu với nhiều nhiều hợp lệ dựa trên kiến thức miền, các nghiên cứu [47]-[49] và ý kiến chuyên gia tại một trung tâm vận hành an ninh mạng hợp tác. Do trong tấn công né tránh, đối thủ chỉ kiểm soát các gói gửi từ một hướng, nhiều được áp dụng lên gói hướng đi của từng loại tấn công. Các mẫu vẫn giữ nguyên chức năng truyền thông.

Bảng X mô tả năm kiểu nhiễu, giá trị và các byte cần sửa để duy trì tính hợp lệ của gói. Mẫu đối kháng được tạo từ dữ liệu ảnh chín gói. Hai kịch bản được trình bày: (i) gây nhiễu một nửa số gói hướng đi trong mỗi luồng bằng cả năm phương pháp; (ii) gây nhiễu toàn bộ gói hướng đi bằng cả năm phương pháp.

Bảng X. Các phương pháp gây nhiễu dùng để tạo mẫu đối kháng

Phương pháp	Mô tả	Các byte bị ảnh hưởng
Thêm dữ liệu payload	Chèn 40 byte payload không có tác dụng, chẳng hạn 0xFF, ở cuối payload gốc.	Ảnh hưởng byte payload và byte checksum TCP từ tiêu đề TCP, byte 17 và 18.
Thay đổi delta time	Tăng delta time của gói được chọn bằng một độ trễ, ví dụ 0,001 ms.	Chỉ thay đổi quan hệ thời gian giữa các gói; không thay đổi byte gói.
Thay đổi window size	Tăng hoặc giảm các byte window size trong phạm vi ± 256 ; giá trị hợp lệ cuối cùng nằm trong 1-65535.	Thay đổi byte window size của TCP, byte 15-16, và checksum TCP, byte 17-18.
Thay đổi TTL	Tăng hoặc giảm TTL trong khoảng 0-255; giá trị khởi tạo khuyến nghị 64.	Thay đổi TTL của IP, byte 9, và checksum IP, byte 11-12.
Thay đổi phân mảnh	Đổi bit phân mảnh từ không phân mảnh sang phân mảnh; chỉ áp dụng khi phân mảnh đang tắt.	Thay đổi byte fragmentation của IP, byte 7-8, TTL byte 9 và checksum IP byte 11-12.

Để so sánh, các mẫu nhiễu được kiểm thử trên NIDS dựa trên gói và luồng trong [49], [50], gồm Decision Tree, Random Forest, SVM, k-NN và DNN. Tỷ lệ né tránh trên các NIDS này nằm trong khoảng 70%-99% tùy loại tấn công. Với SPIN-IDS, tỷ lệ né tránh tối đa chỉ 2,04%, và chỉ xuất hiện ở một số loại như DoS Slowloris, DoS Hulk, Infiltration và Port Scan. Bảng XI cho thấy khả năng chống chịu mạnh trước tấn công né tránh.

Bảng XI. Hiệu năng mô hình trước tấn công đối kháng

Tấn công	ER khi gây nhiễu 50% gói hướng đi	ER khi gây nhiễu 100% gói hướng đi
DoS Slowloris	0	2,04
DoS Slowhttptest	0	0
DoS Hulk	2,04	2,04
DoS GoldenEye	0	0
Heartbleed	0	0
FTP-Patator	0	0
SSH-Patator	0	0
Web Attack-Brute Force	0	0
Infiltration	0	2,04
PortScan	0	2,04
DDoS	0	0

D. Hiệu năng trong môi trường đích mới

Để đánh giá khả năng thích nghi miền, nghiên cứu dùng CIC-IDS2018, xử lý bằng khung SPIN-IDS. Bộ phân tích gói trích xuất đặc trưng từ pcap, bộ tạo ảnh sinh các ảnh, sau đó ảnh được đưa vào bộ phát hiện đã huấn luyện hoàn toàn bằng CIC-IDS2017.

Thiết lập đánh giá tương tự CIC-IDS2017: dùng nhiều dạng ảnh với số gói tuần tự khác nhau. Bảng XII cho thấy mô hình có hiệu năng tương tự trên môi trường mới. Ảnh tám và chín gói có chỉ số tốt nhất, củng cố nhận định rằng ý đồ độc hại có thể được phát hiện sớm. Bảng XIII trình bày hiệu năng trên ảnh chín gói của một số loại tấn công trong CIC-IDS2018. Dù chỉ được huấn luyện trên CIC-IDS2017, mô hình vẫn phát hiện tốt tấn công ở môi trường khác. Điều này cho thấy SPIN-IDS có thể được triển khai ở trung tâm vận hành an ninh mà không nhất thiết phải huấn luyện lại từ đầu.

Bảng XII. Khả năng thích nghi miền theo dạng ảnh của CIC-IDS2018

Tập con	Số mẫu	Accuracy	Precision	F1	TNR	FNR	TPR	FPR
1	230650	0,8207	0,9371	0,8171	0,9399	0,2756	0,7244	0,0601
2	185787	0,8462	0,9348	0,8034	0,9604	0,2956	0,7044	0,0396
3	178059	0,9004	0,9519	0,8725	0,9701	0,1946	0,8054	0,0299
4	175466	0,9524	0,9481	0,9432	0,9627	0,0617	0,9383	0,0373
5	174967	0,9625	0,9619	0,9549	0,9729	0,0519	0,9481	0,0271
6	174397	0,9687	0,9676	0,9624	0,9769	0,0427	0,9573	0,0231
7	171170	0,9719	0,9717	0,9669	0,9791	0,0379	0,9621	0,0209
8	169967	0,9743	0,9736	0,9699	0,9804	0,0339	0,9661	0,0196
9	160211	0,9744	0,9721	0,9677	0,9817	0,0368	0,9632	0,0183
10	158801	0,9740	0,9727	0,9671	0,9822	0,0385	0,9615	0,0178
11	140846	0,9746	0,9696	0,9627	0,9844	0,0442	0,9558	0,0156
12	136870	0,9742	0,9726	0,9622	0,9858	0,0480	0,9520	0,0142
13	130653	0,9750	0,9788	0,9649	0,9883	0,0487	0,9513	0,0117
14	121919	0,9737	0,9831	0,9652	0,9898	0,0520	0,9480	0,0102
15	107890	0,9724	0,9869	0,9675	0,9904	0,0511	0,9489	0,0096

Bảng XIII. Phân tích phát hiện theo loại tấn công trên CIC-IDS2018

Tấn công	Số mẫu	Accuracy	Precision	F1	TNR	FNR	TPR	FPR
DoS Slowloris	6186	0,9510	0,9664	0,9505	0,9672	0,0550	0,9350	0,0328
DoS GoldenEye	36513	0,9714	0,9665	0,9699	0,9698	0,0267	0,9733	0,0302
SSH-Patator	84921	0,9782	0,9709	0,9782	0,9707	0,0143	0,9857	0,0293
Web Attack-Brute Force	545	0,9450	0,9542	0,9434	0,9567	0,0572	0,9328	0,0433
Web Attack-XSS	325	0,9508	0,9321	0,9497	0,9349	0,0321	0,9679	0,0651
Infiltration	2181	0,9431	0,9616	0,9389	0,9668	0,0829	0,9171	0,0332

E. So sánh với các phương pháp khác

Mục tiêu chính của SPIN-IDS là phát hiện chính xác lưu lượng độc hại theo thời gian thực hoặc gần thời gian thực bằng số gói tối thiểu trong luồng đang diễn tiến. Việc so sánh trực tiếp với phương pháp khác khó khăn do khác biệt về phương pháp và cách biểu diễn dữ liệu. Vì vậy, nghiên cứu trước hết so sánh SPIN-IDS dùng ảnh RGB với các mô hình cơ sở dùng dữ liệu số phẳng; sau đó so sánh với NIDS tiên tiến sử dụng thông tin gói tin.

1) So sánh với mô hình cơ sở

Từ mỗi luồng CIC-IDS2017, chín gói được lấy tuần tự, nối lại và biểu diễn dưới dạng vector phẳng cho các mô hình cơ sở. Các mô hình gồm Random Forest, AdaBoost, Multilayer Perceptron, DNN năm lớp và 1D-CNN bốn lớp. Việc lựa chọn mô hình và siêu tham số dựa trên tính phổ biến và hiệu quả đã được xác lập trong tài liệu [51]. Các mô hình này được so sánh với SPIN-IDS dùng ảnh của chính các luồng đó.

Bảng XIV cho thấy SPIN-IDS vượt mọi mô hình cơ sở trên tất cả chỉ số. Với không gian đặc trưng rất lớn của dữ liệu gói, 1D-CNN có hiệu năng gần Random Forest; tuy nhiên SPIN-IDS vượt 1D-CNN hơn 5% về F1-score. Điều này chứng minh biểu diễn RGB giúp nhận diện các mẫu tấn công nền hiệu quả hơn.

Bảng XIV. So sánh SPIN-IDS với các mô hình cơ sở

Phương pháp	Accuracy	Precision	Recall	F1
RF	0,9544	0,9435	0,9345	0,9356
AdaBoost Classifier	0,8734	0,8435	0,8456	0,8432
MLP	0,8323	0,8213	0,8045	0,8101
DNN	0,9021	0,8867	0,8935	0,8967
1D-CNN	0,9563	0,9467	0,9332	0,9334
SPIN-IDS	0,9878	0,9877	0,9878	0,9878

2) So sánh với NIDS tiên tiến

Bảng XV so sánh SPIN-IDS với các mô hình DL dựa trên gói tin dùng cùng CIC-IDS2017 và các chỉ số chính [52]: AEIDS [53], HAST-II [54], PL-RNN [55], Packet2Vec [56], PayloadEmbeddings [52] và PBCNN [33]. Bảng còn nêu tổng thời gian huấn luyện và thời gian kiểm thử/suy luận trên mỗi đơn vị, tính bằng mili giây; một đơn vị có thể là một gói hoặc một ảnh tùy phương pháp.

Để đánh giá chính xác, thời gian kiểm thử của SPIN-IDS gồm cả thời gian tạo ảnh và suy luận. Tạo một ảnh mất trung bình 0,92 ms khi xét các chuỗi từ một đến 15 gói. Tổng thời gian tạo ảnh và suy luận là 1,04 ms. SPIN-IDS đạt chỉ số tốt hơn và thời gian kiểm thử ngắn hơn các phương pháp khác. PBCNN gần nhất về hiệu năng nhưng cần 20 gói, trong khi SPIN-IDS tốt hơn chỉ với chín gói.

Tổng thời gian huấn luyện chịu ảnh hưởng của siêu tham số, phần cứng và số mẫu, nên không nên so sánh phương pháp chỉ dựa trên thời gian huấn luyện. Yếu tố quan trọng hơn là thời gian suy luận vì nó quyết định khả năng phát hiện sớm. SPIN-IDS vượt các mô hình khác nhờ kiến trúc bộ phát hiện có số tham số ít hơn đáng kể.

Bảng XV. So sánh SPIN-IDS với NIDS dựa trên gói tin tiên tiến

Phương pháp	Accuracy	Precision	Recall	F1	Thời gian huấn luyện	Thời gian kiểm thử
PL-RNN	0,6825	0,8335	0,5638	0,6934	720000	2,91
Packet2Vec	0,6625	0,8435	0,7284	0,6273	515000	3,54
HAST-II	0,6423	0,8856	0,6898	0,7498	676000	4,2
AEIDS	0,7736	0,6325	0,5872	0,6182	275800	2,65
PayloadEmbeddings	0,9538	0,9536	0,9535	0,9534	355000	2,73
PBCNN	0,9821	0,9831	0,9830	0,9835	368000	7,89
SPIN-IDS	0,9878	0,9877	0,9878	0,9878	314800	1,04

VI. KẾT LUẬN VÀ HƯỚNG NGHIÊN CỨU TƯƠNG LAI

Nghiên cứu đề xuất khung SPIN-IDS có hỗ trợ AI nhằm phát hiện tấn công mạng theo thời gian thực hoặc gần thời gian thực. Phương pháp khắc phục hạn chế của NIDS dựa trên gói tin bằng cách phân tích đồng thời dữ liệu tiêu đề và payload, đồng thời xét mối liên hệ theo thời gian giữa các gói thuộc cùng một phiên truyền thông khi chúng được truyền qua mạng. Các gói tuần tự trong một luồng đang diễn tiến được biến đổi thành ảnh hai chiều rồi đưa qua bộ phát hiện dựa trên CNN.

Kết quả cho thấy SPIN-IDS với ảnh chín gói tuần tự hoạt động rất tốt. Recall trên các loại tấn công nằm trong khoảng 97,7%-99%, chứng tỏ mô hình nhận diện được các mẫu độc hại nền. Ý đồ độc hại có thể được phát hiện với độ chính xác rất cao khi gói thứ chín được truyền trong phiên hai chiều. Vì vậy, tấn công được phát hiện sớm hơn đáng kể so với phương pháp dựa trên luồng, vốn trung bình phải chờ 80 gói hoặc nhiều hơn.

Mô hình đã huấn luyện cũng có khả năng chuyển giao cao, đạt recall hoặc detection rate trung bình trên 95% ở bộ dữ liệu đích mới. Điều này mở ra khả năng triển khai cùng mô hình ở nhiều môi trường mà không cần huấn luyện lại từ đầu. SPIN-IDS còn vững trước mẫu đối kháng: bộ phát hiện vẫn nhận diện chính xác tấn công khi các gói đã bị gây nhiễu nhiều có chủ đích, trong khi các NIDS ML/DL coi gói độc lập có thể chịu tỷ lệ âm tính giả cao.

Để tiếp tục phát triển và hỗ trợ triển khai thực tế, cần đánh giá SPIN-IDS trong một môi trường mạng thật, kết hợp diễn tập red team bằng các tác tử đối kháng có hỗ trợ AI. Đánh giá này sẽ cung cấp hiểu biết sâu hơn về khả năng chống chịu của khung và mức độ tinh vi cần thiết để vượt qua cơ chế phát hiện thông qua quá trình tiến hóa đối kháng.

LỜI CẢM ƠN

Các tác giả cảm ơn Tiến sĩ Tapas K. Das, Soumyadeep Hore và Diwas Paudel tại University of South Florida vì nhiều trao đổi hữu ích. Những quan điểm và kết luận trong bài là của riêng các tác giả, không phản ánh chính sách hoặc quan điểm chính thức của U.S. Military Academy, U.S. Army, U.S. Department of Defense hoặc Chính phủ Hoa Kỳ.

TÀI LIỆU THAM KHẢO

Danh mục được giữ nguyên tiếng Anh để bảo toàn thông tin thư mục và thuận tiện tra cứu.

- [1] K. He, D. D. Kim, and M. R. Asghar, “Adversarial machine learning for network intrusion detection systems: A comprehensive survey,” *IEEE Commun. Surv. Tut.*, vol. 25, no. 1, pp. 538–566, First Quarter, 2023.
- [2] W. Lee et al., “Real time data mining-based intrusion detection,” in *Proc. DARPA Inf. Survivability Conf. Expo. II*, 2001, pp. 89–100.
- [3] J. Liu et al., “Deep anomaly detection in packet payload,” *Neurocomputing*, vol. 485, pp. 205–218, 2022. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S0925231221016349>
- [4] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward generating a new intrusion detection dataset and intrusion traffic characterization,” *ICISSp*, vol. 1, pp. 108–116, 2018.
- [5] “Zeek,” 2020. Accessed: Dec. 11, 2022. [Online]. Available: <https://zeek.org>
- [6] P. Cheng, M. Han, and G. Liu, “DESC-IDS: Towards an efficient realtime automotive intrusion detection system based on deep evolving stream clustering,” *Future Gener. Comput. Syst.*, vol. 140, pp. 266–281, 2023. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S0167739X22003351>
- [7] C. Kreibich, M. Handley, and V. Paxson, “Network intrusion detection: Evasion, traffic normalization, and end-to-end protocol semantics,” in *Proc. USENIX Secur. Symp.*, 2001, pp. 115–131.
- [8] S. Gu and L. Rigazio, “Towards deep neural network architectures robust to adversarial examples,” 2014, arXiv:1412.5068.
- [9] Y. Jia, M. Wang, and Y. Wang, “Network intrusion detection algorithm based on deep neural network,” *IET Inf. Secur.*, vol. 13, no. 1, pp. 48–53, 2019.
- [10] S. Hettich, “Kdd CUP 1999 data,” *The UCI KDD Arch.*, 1999.
- [11] M. Tavallaee, E. Bagheri, W. Lu, and A. A. Ghorbani, “A detailed analysis of the KDD CUP 99 data set,” in *Proc. IEEE Symp. Comput. Intell. Secur. Defense Appl.*, 2009, pp. 1–6.
- [12] C. Yin, Y. Zhu, J. Fei, and X. He, “A deep learning approach for intrusion detection using recurrent neural networks,” *IEEE Access*, vol. 5, pp. 21954–21961, 2017.
- [13] C. Xu, J. Shen, X. Du, and F. Zhang, “An intrusion detection system using a deep neural network with gated recurrent units,” *IEEE Access*, vol. 6, pp. 48697–48707, 2018.
- [14] S. Naseer et al., “Enhanced network anomaly detection based on deep neural networks,” *IEEE Access*, vol. 6, pp. 48231–48246, 2018.
- [15] S. Zavrak and M. İskefiyeli, “Flow-based intrusion detection on softwaredefined networks: A multivariate time series anomaly detection approach,” *Neural Comput. Appl.*, vol. 35, no. 16, pp. 12175–12193, 2023.
- [16] C. Fu, Q. Li, K. Xu, and J. Wu, “Point cloud analysis for ML-based malicious traffic detection: Reducing majorities of false positive alarms,” in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur.*, New York, NY, USA, 2023, pp. 1005–1019, doi: 10.1145/3576915.3616631.
- [17] Y. Chai, L. Du, J. Qiu, L. Yin, and Z. Tian, “Dynamic prototype network based on sample adaptation for few-shot malware detection,” *IEEE Trans. Knowl. Data Eng.*, vol. 35, no. 5, pp. 4754–4766, May 2023.
- [18] F. Farahnakian and J. Heikkonen, “A deep auto-encoder based approach for intrusion detection system,” in *Proc. 20th Int. Conf. Adv. Commun. Technol.*, 2018, pp. 178–183.
- [19] N. Shone, T. N. Ngoc, V. D. Phai, and Q. Shi, “A deep learning approach to network intrusion detection,” *IEEE Trans. Emerg. Topics Comput. Intell.*, vol. 2, no. 1, pp. 41–50, Feb. 2018.
- [20] K. Alrawashdeh and C. Purdy, “Toward an online anomaly intrusion detection system based on deep learning,” in *Proc. 15th IEEE Int. Conf. Mach. Learn. Appl.*, 2016, pp. 195–200.
- [21] B. Yan and G. Han, “Effective feature extraction via stacked sparse autoencoder to improve intrusion detection system,” *IEEE Access*, vol. 6, pp. 41238–41248, 2018.
- [22] Y. Yang, K. Zheng, B. Wu, Y. Yang, and X. Wang, “Network intrusion detection based on supervised adversarial variational auto-encoder with regularization,” *IEEE Access*, vol. 8, pp. 42169–42184, 2020.
- [23] S. Zavrak and M. İskefiyeli, “Anomaly-based intrusion detection from network flow features using variational autoencoder,” *IEEE Access*, vol. 8, pp. 108346–108358, 2020.
- [24] M. Roopak, G. Y. Tian, and J. Chambers, “Deep learning models for cyber security in IoT networks,” in *Proc. IEEE 9th Annu. Comput. Commun. Workshop Conf.*, 2019, pp. 0452–0457.

- [25] P. Sun et al., “DL-IDS: Extracting features using CNN-LSTM hybrid network for intrusion detection system,” *Secur. Commun. Netw.*, vol. 2020, pp. 1–11, 2020.
- [26] K. Jiang, W. Wang, A. Wang, and H. Wu, “Network intrusion detection combined hybrid sampling with deep hierarchical network,” *IEEE Access*, vol. 8, pp. 32464–32476, 2020.
- [27] Y. Yu and N. Bian, “An intrusion detection method using few-shot learning,” *IEEE Access*, vol. 8, pp. 49730–49740, 2020.
- [28] Z.-Q. Qin, X.-K. Ma, and Y.-J. Wang, “Attentional payload anomaly detector for web applications,” in *Proc. Neural Inf. Process.: 25th Int. Conf.*, Siem Reap, Cambodia, 2018, pp. 588–599.
- [29] I. Sharafaldin, A. Habibi Lashkari, and A. A. Ghorbani, “A detailed analysis of the CICIDS2017 data set,” in *Proc. Inf. Syst. Secur. Privacy: 4th Int. Conf.*, Funchal-Madeira, Portugal, 2019, pp. 172–188.
- [30] Y. A. Farrukh, I. Khan, S. Wali, D. Bierbrauer, J. A. Pavlik, and N. D. Bastian, “Payload-byte: A tool for extracting and labeling packet capture files of modern network intrusion detection datasets,” in *Proc. IEEE/ACM Int. Conf. Big Data Comput., Appl. Technologies (BDCAT)*, 2022, pp. 58–67.
- [31] J. Holland, P. Schmitt, N. Feamster, and P. Mittal, “New directions in automated traffic analysis,” in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur.*, 2021, pp. 3366–3383.
- [32] X. Zhang, J. Chen, Y. Zhou, L. Han, and J. Lin, “A multiple-layer representation learning model for network-based attack detection,” *IEEE Access*, vol. 7, pp. 91992–92008, 2019.
- [33] L. Yu et al., “PBCNN: Packet bytes-based convolutional neural network for network intrusion detection,” *Comput. Netw.*, vol. 194, 2021, Art. no. 108117.
- [34] L. F. Sikos, “Packet analysis for network forensics: A comprehensive survey,” *Forensic Sci. Int.: Digit. Investigation*, vol. 32, 2020, Art. no. 200892.
- [35] M. M. Alani, *Guide to OSI and TCP/IP Models*. Berlin, Germany: Springer, 2014.
- [36] M. Masum and H. Shahriar, “TL-NID: Deep neural network with transfer learning for network intrusion detection,” in *Proc. 15th Int. Conf. Internet Technol. Secured Trans.*, 2020, pp. 1–7.
- [37] F. Özyurt, E. Ava, and E. Sert, “UC-merced image classification with CNN feature reduction using wavelet entropy optimized with genetic algorithm,” *Traitement Du Signal*, vol. 37, no. 3, pp. 347–353, Apr. 2020, doi: 10.18280/ts.370301.
- [38] H. Hindy et al., “A taxonomy of network threats and the effect of current datasets on intrusion detection systems,” *IEEE Access*, vol. 8, pp. 104650–104675, 2020.
- [39] “dpkt 1.9.2 documentation,” 2009. Accessed: Feb. 16, 2023. [Online]. Available: <https://dpkt.readthedocs.io/en/latest/>
- [40] “Scapy 2.5.0 documentation,” 2010. Accessed: Jan. 11, 2023. [Online]. Available: <https://scapy.readthedocs.io/en/latest/>
- [41] G. Engelen, V. Rimmer, and W. Joosen, “Troubleshooting an intrusion detection dataset: The CICIDS2017 case study,” in *Proc. IEEE Secur. Privacy Workshops*, 2021, pp. 7–12.
- [42] M. Abadi et al., “TensorFlow: Large-scale machine learning on heterogeneous systems,” 2015. [Online]. Available: <https://www.tensorflow.org/>
- [43] T. O’Malley et al., “Kerastuner,” 2019. [Online]. Available: <https://github.com/keras-team/keras-tuner>
- [44] X. Glorot and Y. Bengio, “Understanding the difficulty of training deep feedforward neural networks,” in *Proc. 13th Int. Conf. Artif. Intell. Statist.*, 2010, pp. 249–256. [Online]. Available: <https://proceedings.mlr.press/v9/glorot10a.html>
- [45] K. He, X. Zhang, S. Ren, and J. Sun, “Delving deep into rectifiers: Surpassing human-level performance on imagenet classification,” 2015, arXiv:1502.01852.
- [46] Z. Wang, A. Bovik, H. Sheikh, and E. Simoncelli, “Image quality assessment: From error visibility to structural similarity,” *IEEE Trans. Image Process.*, vol. 13, no. 4, pp. 600–612, Apr. 2004.
- [47] M. Nasr, A. Bahramali, and A. Houmansadr, “Defeating DNN-based traffic analysis systems in real-time with blind adversarial perturbations,” in *Proc. USENIX Secur. Symp.*, 2021, pp. 2705–2722.
- [48] A. M. Sadeghzadeh, S. Shiravi, and R. Jalili, “Adversarial network traffic: Towards evaluating the robustness of deep-learning-based network traffic classification,” *IEEE Trans. Netw. Service Manag.*, vol. 18, no. 2, pp. 1962–1976, Jun. 2021.
- [49] H. Yan et al., “Automatic evasion of machine learning-based network intrusion detection systems,” *IEEE Trans. Dependable Secure Comput.*, vol. 21, no. 1, pp. 153–167, Jan./Feb. 2024.
- [50] B.-E. Zolbayer et al., “Generating practical adversarial network traffic flows using nidsgan,” 2022, arXiv:2203.06694.
- [51] Y. A. Farrukh, S. Wali, I. Khan, and N. D. Bastian, “SeNet-I: An approach for detecting network intrusion through serialized network traffic images,” *Eng. Appl. Artif. Intell.*, vol. 126, 2023, Art. no. 107169.
- [52] M. Hassan, M. E. Haque, M. E. Tozal, V. Raghavan, and R. Agrawal, “Intrusion detection using payload embeddings,” *IEEE Access*, vol. 10, pp. 4015–4030, 2021.
- [53] B. A. Pratomio, P. Burnap, and G. Theodorakopoulos, “Unsupervised approach for detecting low rate attacks on network traffic with autoencoder,” in *Proc. Int. Conf. Cyber Secur. Protection Digit. Serv. (Cyber Security)*, 2018, pp. 1–8.
- [54] W. Wang et al., “HAST-IDS: Learning hierarchical spatial-temporal features using deep neural networks to improve intrusion detection,” *IEEE Access*, vol. 6, pp. 1792–1806, 2017.
- [55] H. Liu, B. Lang, M. Liu, and H. Yan, “CNN and RNN based payload classification methods for attack detection,” *Knowl.-Based Syst.*, vol. 163, pp. 332–341, 2019.
- [56] E. L. Goodman, C. Zimmerman, and C. Hudson, “Packet2Vec: Utilizing word2Vec for feature extraction in packet data,” 2020, arXiv: 2004.14477.

TIỂU SỬ TÁC GIẢ

Jalal Ghadermazi hiện là nghiên cứu sinh tiến sĩ tại Department of Industrial and Management Systems Engineering, University of South Florida, chuyên về an ninh mạng. Hướng nghiên cứu của ông gồm độ vững, phân tích thời gian thực và học máy đối kháng trong các ứng dụng an ninh mạng. Ông kết hợp nguyên lý từ khoa học máy tính, nghiên cứu vận trù, khoa học dữ liệu và công nghệ thông tin để phát triển các giải pháp nâng cao an ninh mạng.

Ankit Shah (Thành viên Cao cấp IEEE) là trợ lý giáo sư tại Department of Industrial and Management Systems Engineering và là giám đốc Artificial Intelligence Research Laboratory for Secure and Efficient Systems, University of South Florida. Hướng nghiên cứu của ông nằm tại giao điểm của khoa học máy tính, nghiên cứu vận trù, khoa học dữ liệu và công nghệ thông tin, tập trung mạnh vào AI cho an ninh mạng. Nghiên cứu phương pháp của ông gồm học tăng cường sâu và học máy đối kháng nhằm giảm thiểu mối đe dọa và tăng cường an toàn hệ thống.

Nathaniel D. Bastian (Thành viên Cao cấp IEEE) là trưởng bộ phận Data & Decision Sciences và nhà khoa học nghiên cứu cao cấp tại Army Cyber Institute, West Point; đồng thời giảng dạy Systems Engineering, Mathematical Sciences và Computing tại United States Military Academy. Hướng nghiên cứu của ông nằm tại giao điểm của AI, nghiên cứu vận trù, khoa học dữ liệu và kỹ thuật hệ thống, tập trung vào an toàn, độ vững và khả năng phục hồi của AI; chỉ huy và kiểm soát chiến trường thông minh; và AI cho tác chiến không gian mạng.